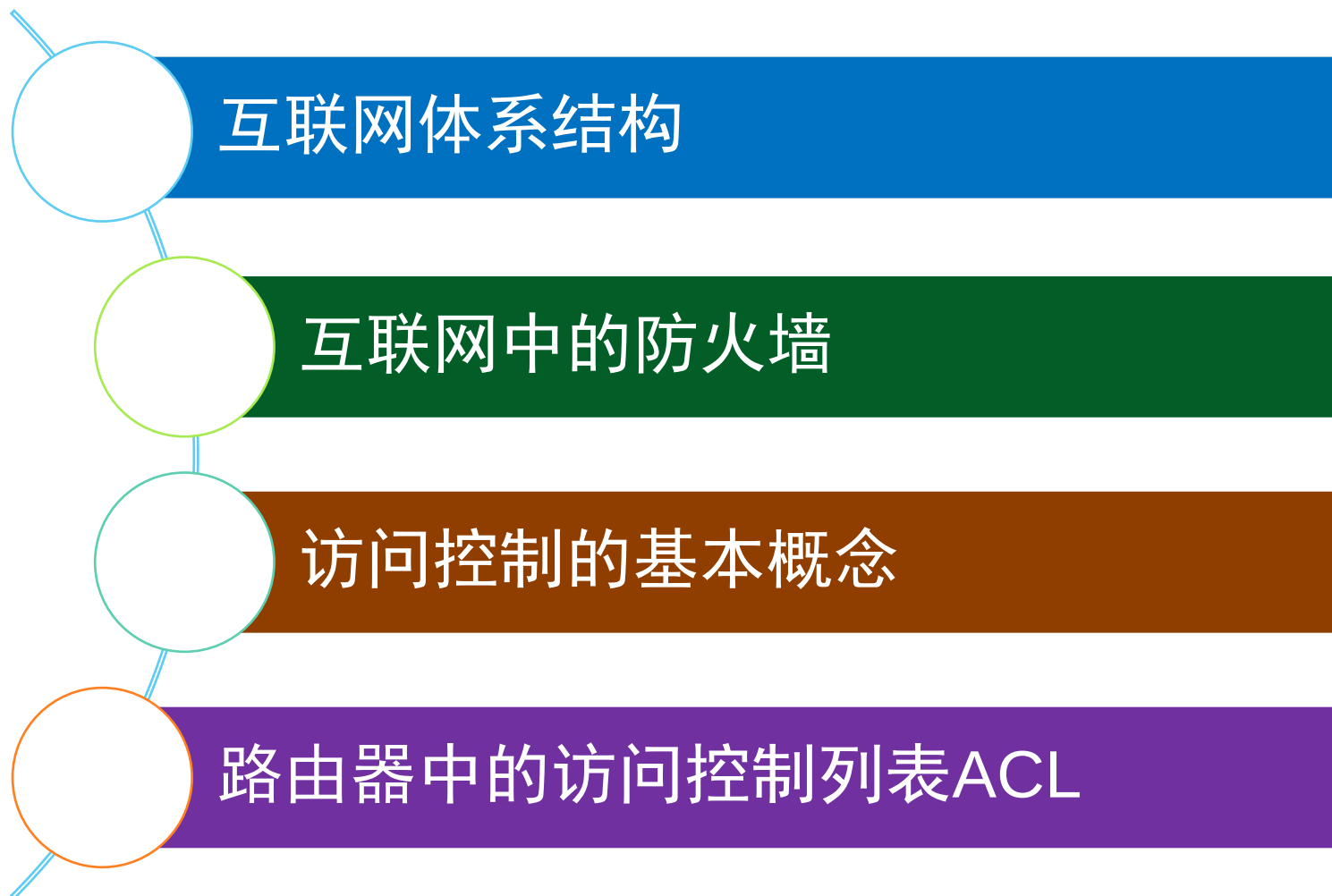




计算机网络安全技术

- 课程代号：40240572
- 课程对象：本科生
- 授课教师：尹 霞
- 开课单位：计算机系网络所

课后作业补充知识

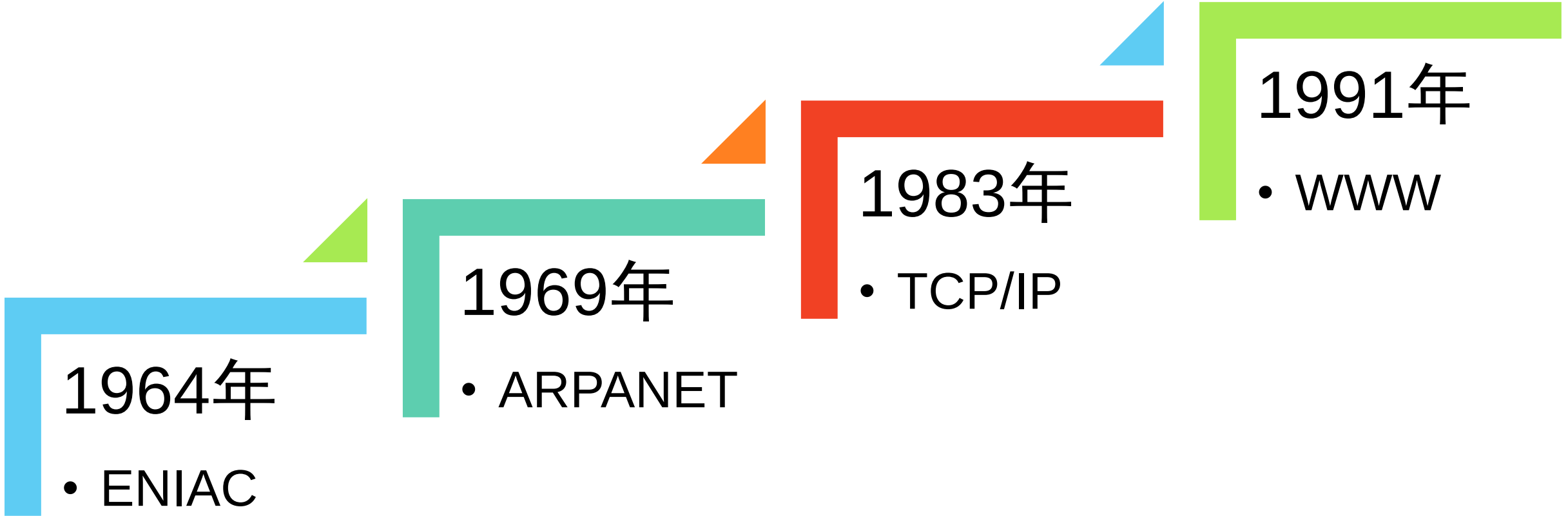




互联网体系结构



几个重要的时间点



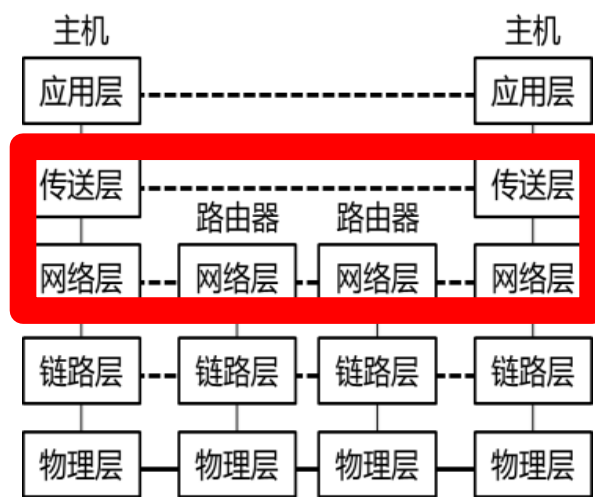
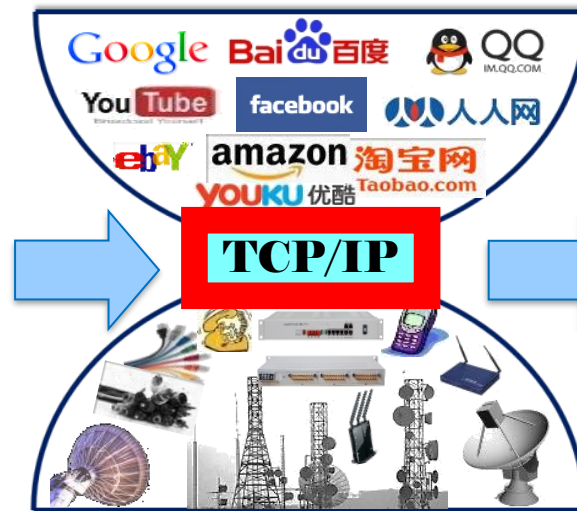
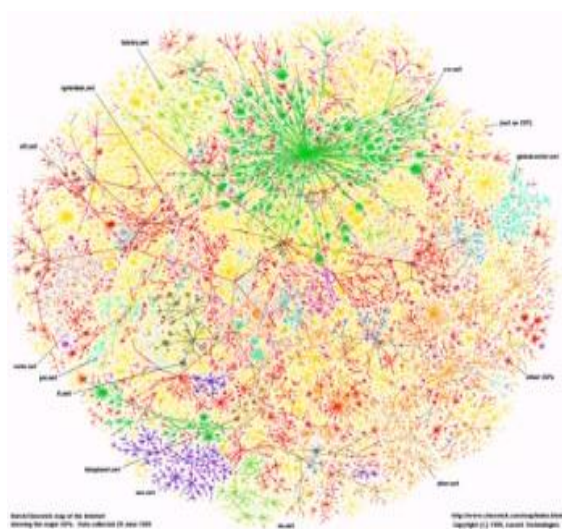
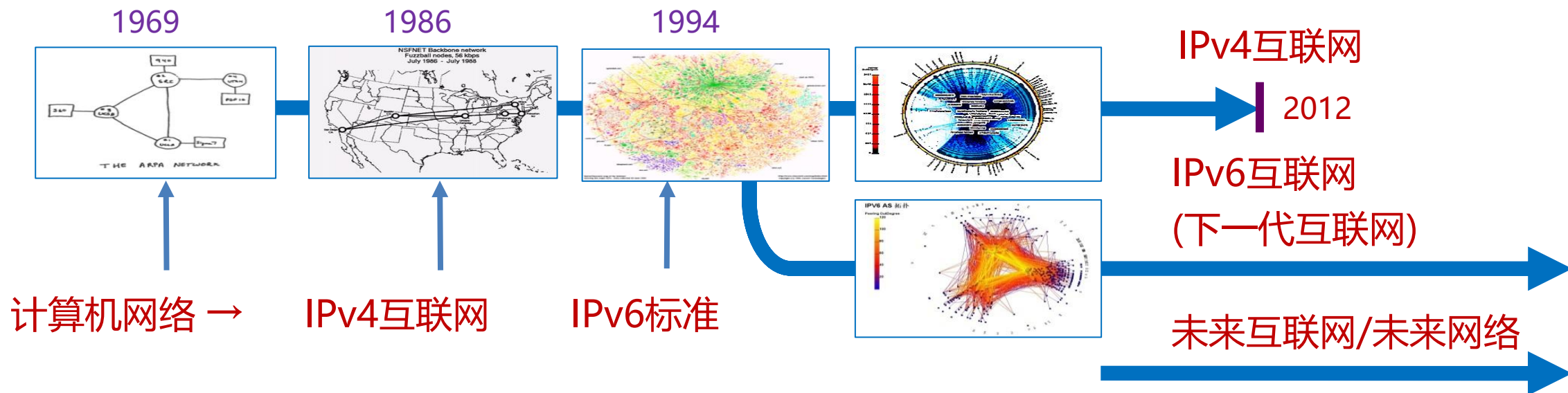
1964年
• ENIAC

1969年
• ARPANET

1983年
• TCP/IP

1991年
• WWW

互联网发展历程和互联网体系结构



- 传送格式
- 转发方式
- 路由控制

互联网体系结构：层和协议的集合

- 将网络这个庞大的、复杂的问题划分成若干较小的、简单的问题，采用分层技术
- 分层技术的原则：层内功能内聚、层间耦合松散
- 分层技术的优势
 - 各层之间相互独立、灵活性好
 - 每层都可以采用最合适的实现技术
 - 易于实现和维护
 - 有利于网络标准化

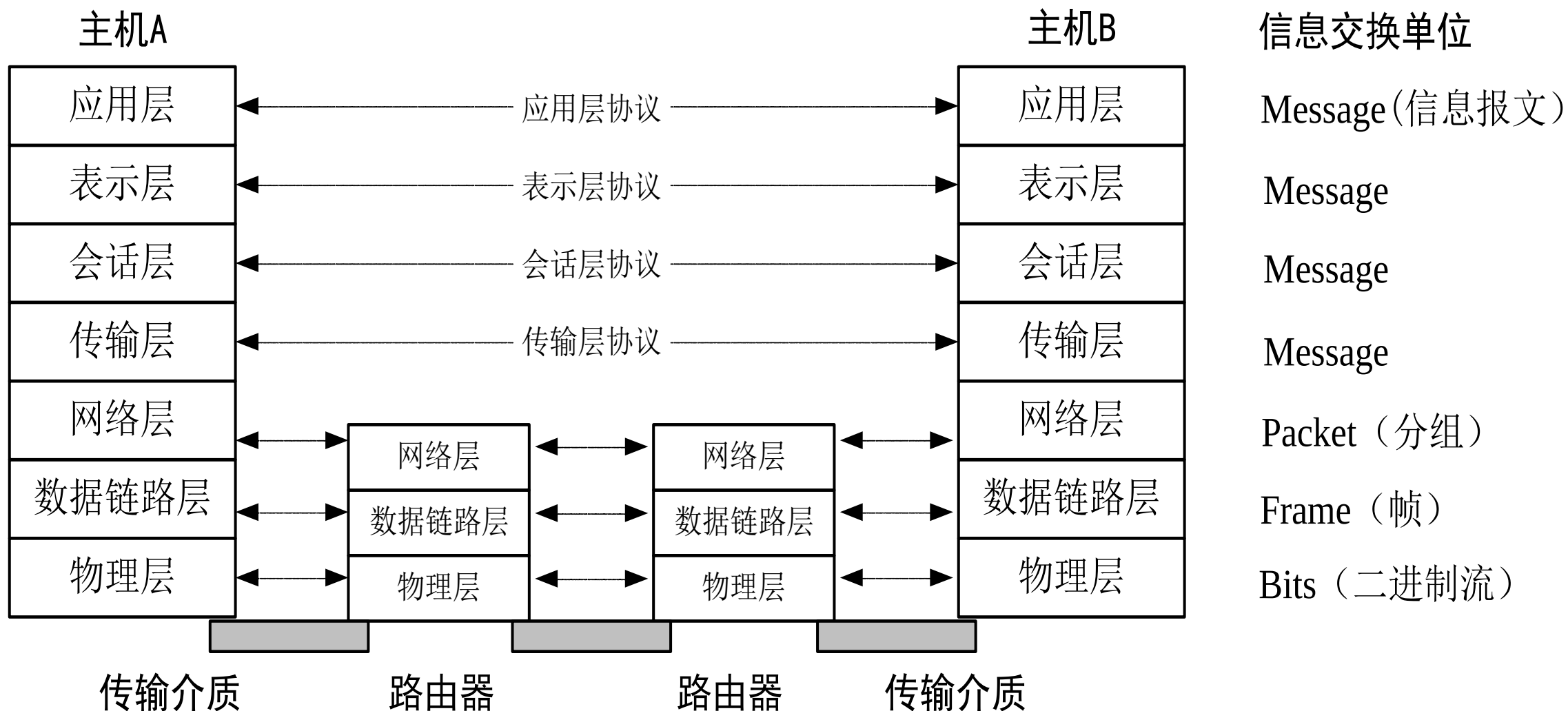
协议

- 网络协议是通信双方为了实现通信所进行的约定或对话规则；协议protocol的优劣直接影响网络的性能，网络协议的组成
 - 语义：做什么（what to do）
 - 语法：怎么做（how to do）
 - 定时关系：何时做（when to do）
- 计算机网络中存在多种协议，协议之间相互作用
 - 为避免重复工作，每个协议应该独立处理和完成某些问题
 - 协议之间可以共享数据和信息

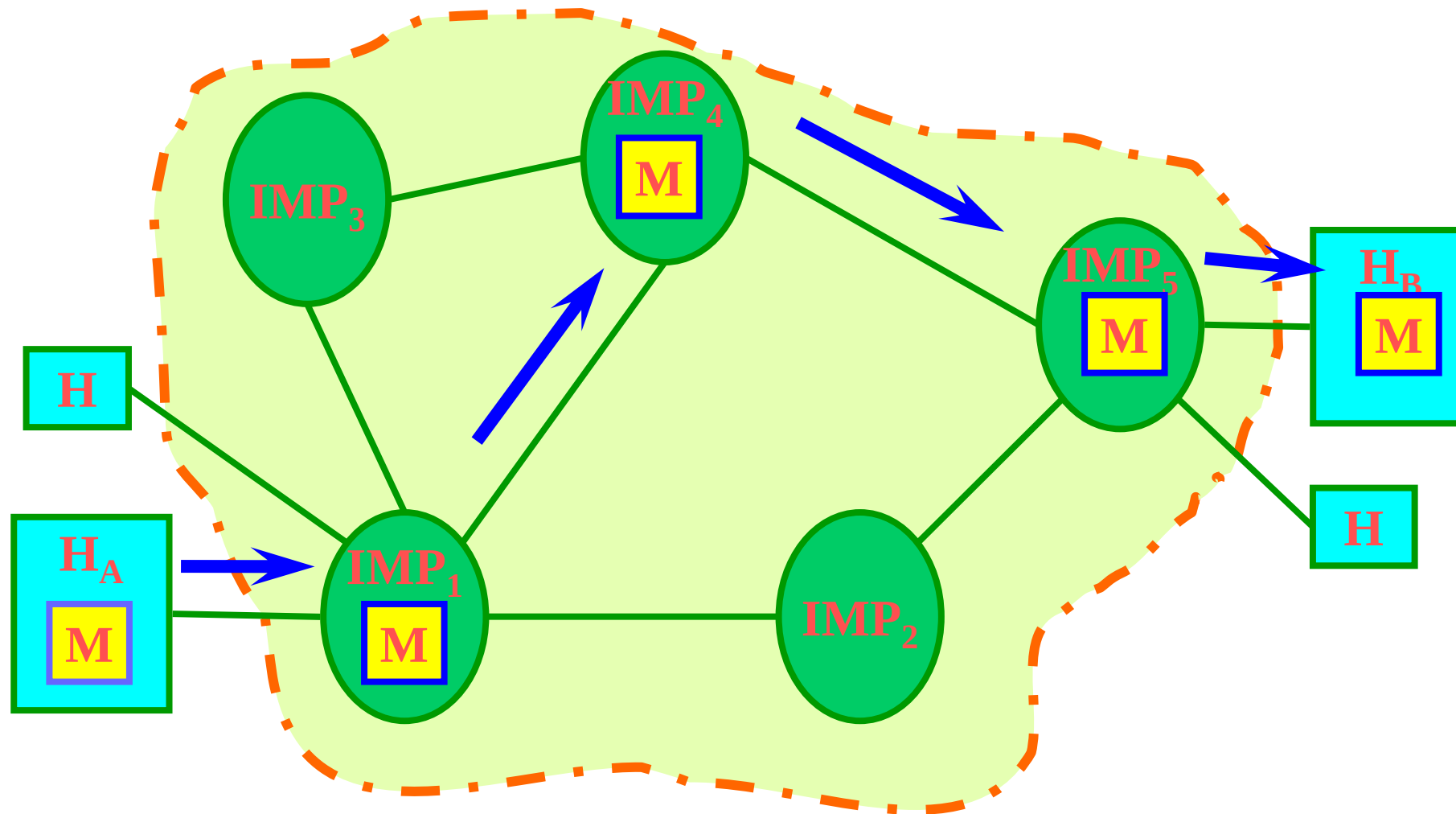
ISO和OSI参考模型

- 1977年，国际标准化组织ISO设立了一个分委员会，专门研究网络通信的体系结构
- 1983年，该委员会提出的开放系统互连参考模型（OSI-RM）各层的协议被批准为国际标准，给网络的发展提供了一个可共同遵守的规则，从此计算机网络的发展走上了标准化的道路
- OSI参考模型是一个描述网络层次结构的模型，定义的主要内容包括：信息在网络中的传输过程、各层的功能和架构
 - OSI参考模型是一个网络体系结构，并非一个现实的网络

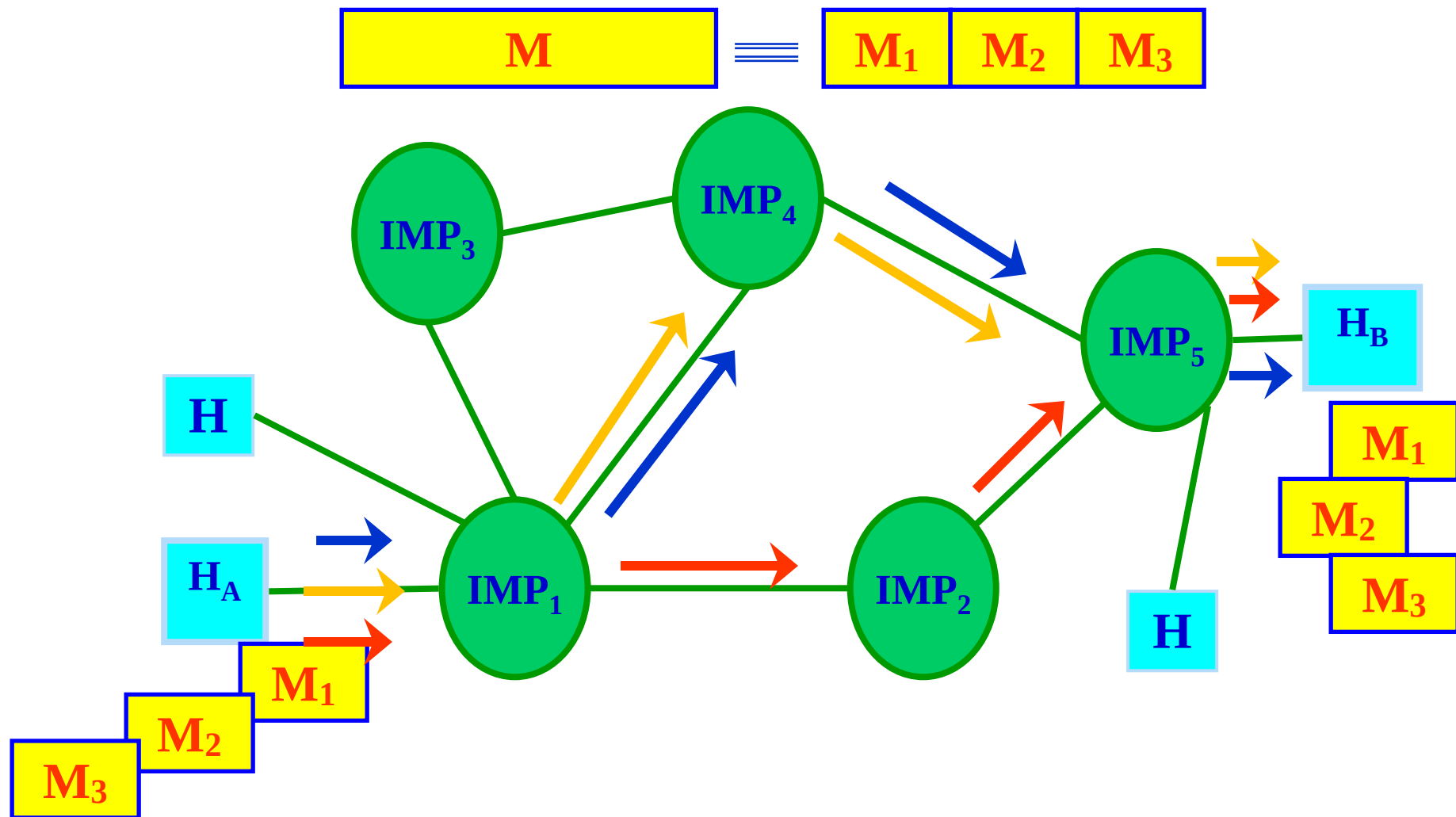
OSI参考模型：基本结构



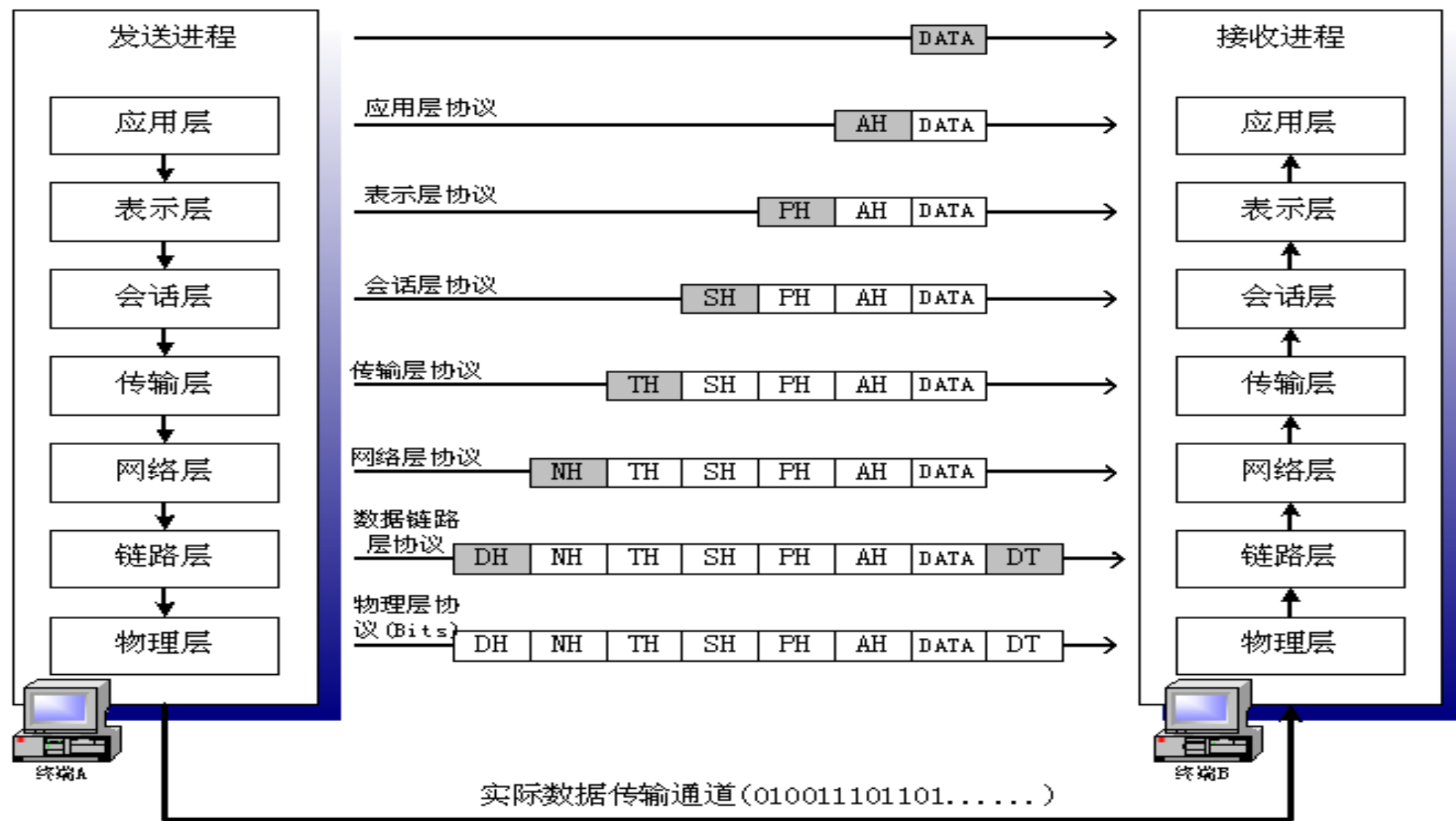
存储转发



分组交换

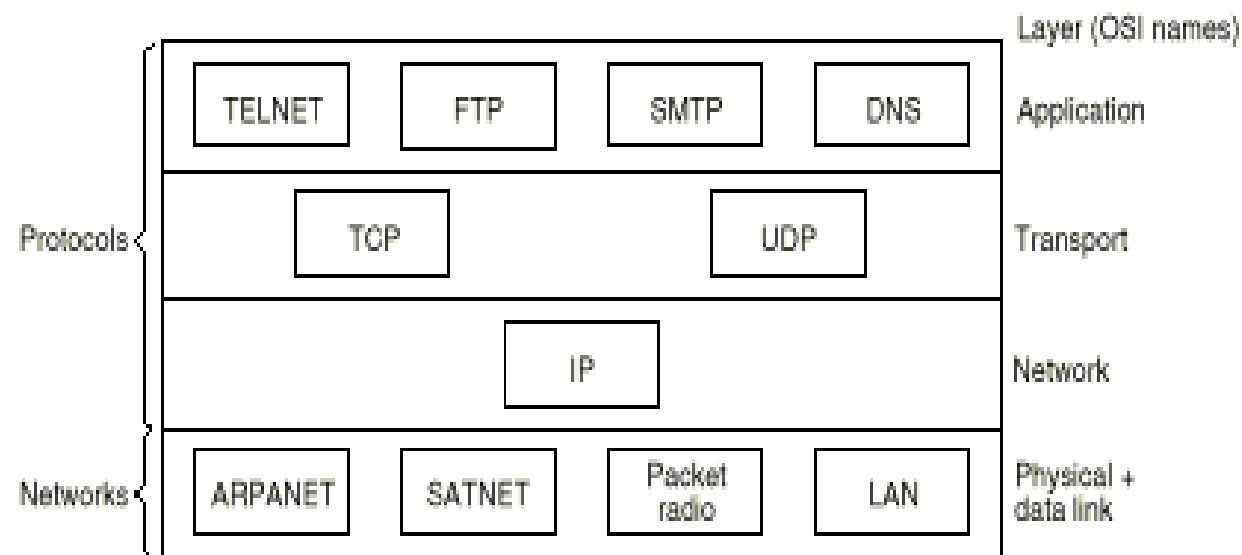


OSI参考模型：数据传递



TCP/IP协议栈

- 网络层协议主要包括：
 - 互联网协议IP
 - 互联网控制报文协议ICMI
- 传输层协议包括：
 - 传输控制协议TCP
 - 用户数据报协议UDP
- 应用层包括所有的高层协议

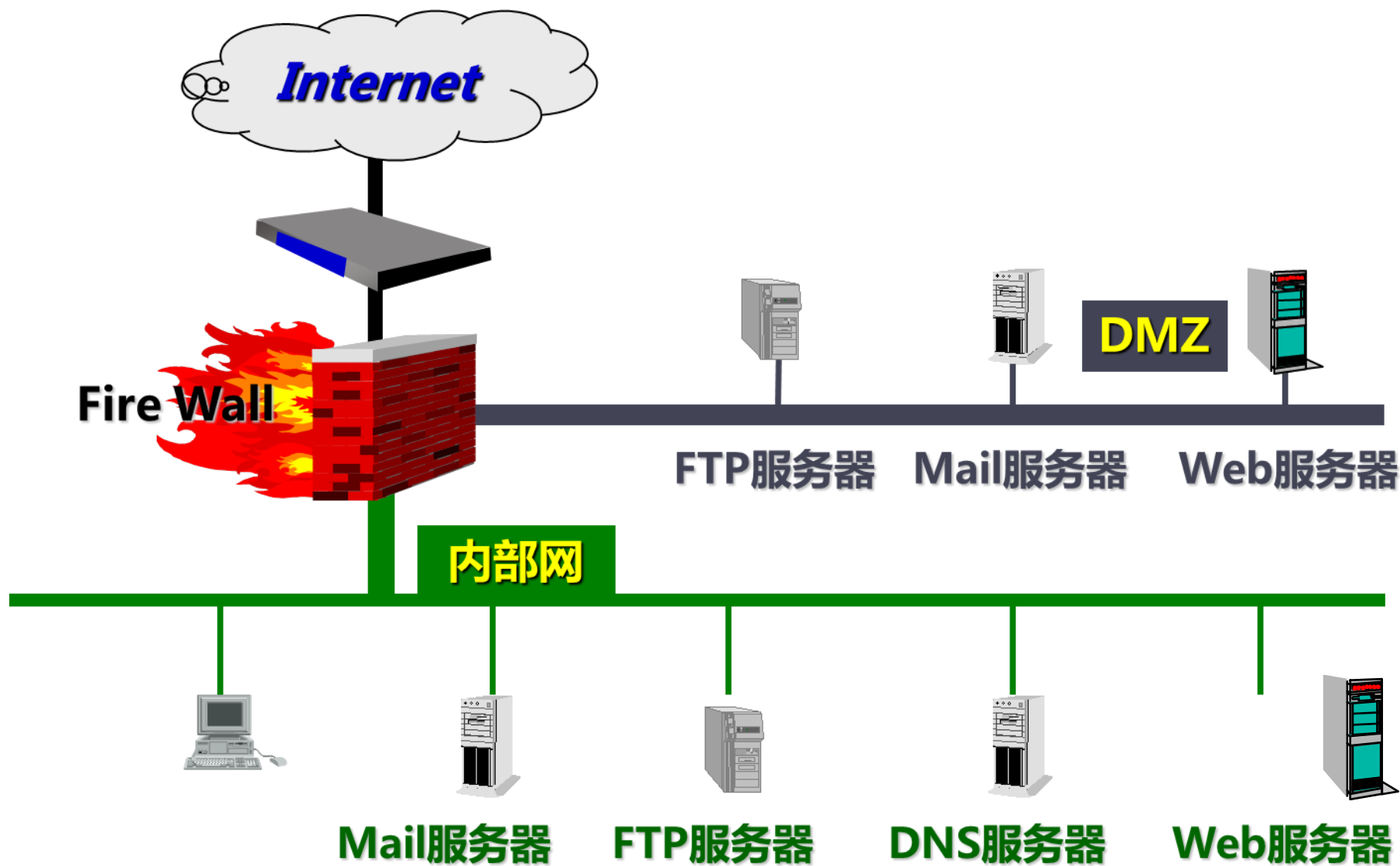




互联网中的防火墙



互联网中的防火墙



防火墙的基本概念

- 防火墙是在被保护网络和其他网络之间实施访问控制政策的一组设备，由软、硬件设备组成、在内网和外网之间、专用网与公共网之间的界面上构造的保护屏障
- 防火墙的作用
 - 隐藏内部网络结构及资源
 - 保护不安全的网络服务
 - 执行网络间的访问控制策略
 - 统一集中的安全管理
 - 监视和预警

防火墙的设计目标

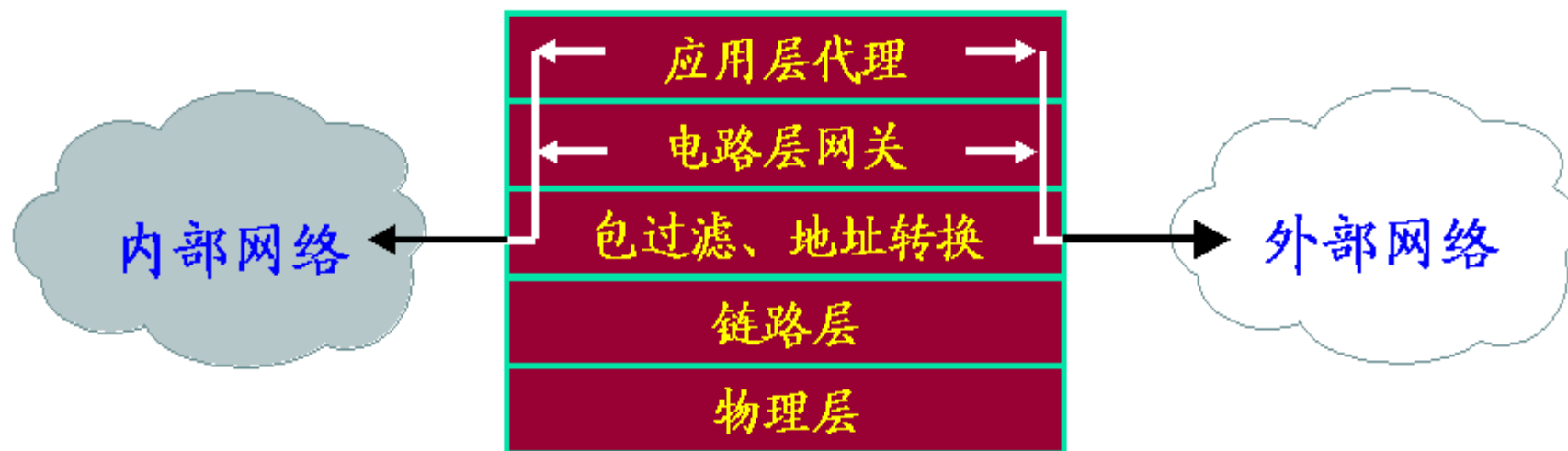
- 所有的通信，无论是从内部到外部还是从外部到内部的，都必须经过防火墙
- 只有授权的通信才能通过防火墙，这些授权将在本地安全策略中规定
- 不同类型的防火墙将实现不同的安全策略
- 防火墙本身对于渗透必须是免疫
 - 意味着必须使用运行安全操作系统可信系统

防火墙的常用技术

- 防火墙常用来控制访问的四项技术：
 - 服务控制(Service Control)
 - 基于服务端口号，基于服务器的IP地址等
 - 方向控制(Direction Control)
 - 比如，内部发起的可以通过，但反之不允许
 - 用户控制(Service Control)
 - 基于用户的身份进行控制，特别是允许外部用户访问内部网络，如VPN
 - 行为控制(Service Control)
 - 基于用户的行为进行控制，如Spam Email filter

防火墙的技术分类

- 防火墙技术上划分为四类
 - 网络层：包过滤技术(Packet filtering/screening)
 - 网络层：地址转换(NAT)
 - 传输层：电路层网关(Circuit Gateway)
 - 应用层：应用层代理(Proxy)

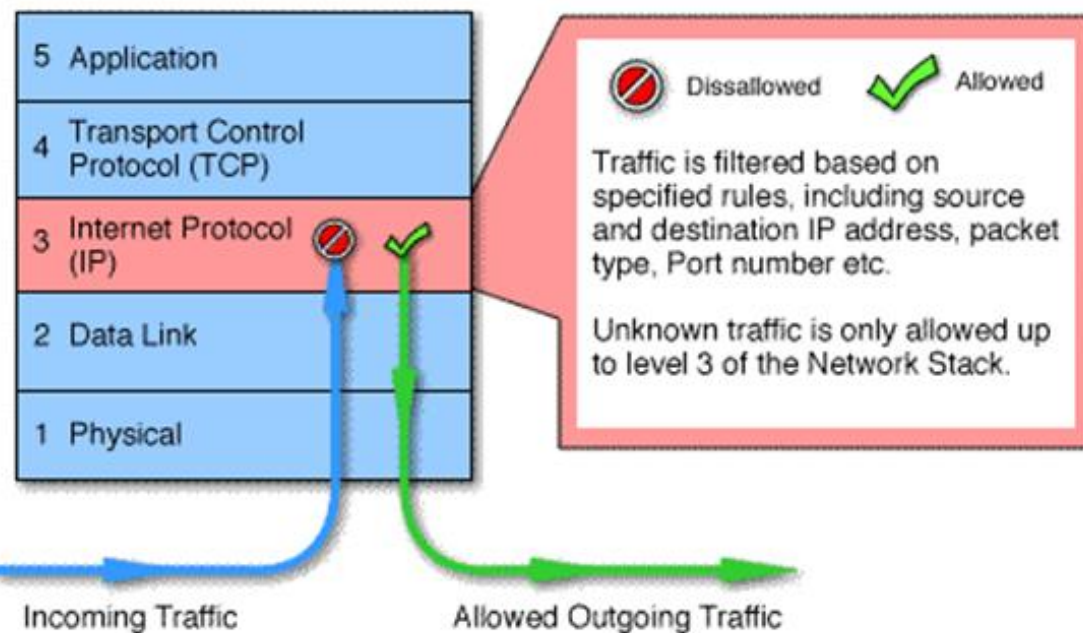


网络层：包过滤技术

- 包过滤技术工作在网络层
- 包过滤路由器依据一套规则对收到的IP包进行处理，决定是转发还是丢弃
- 包过滤技术是一种通用、廉价和有效的安全手段，经历了静态和动态两代
 - 第一代：静态包过滤类型防火墙
 - 第二代：动态包过滤类型防火墙
 - Checkpoint和Cisco的PIX防火墙为包过滤技术防火墙的代表产品

网络层：包过滤类型防火墙

- 包过滤类型防火墙几乎是与路由器同时产生的，它是根据定义好的过滤规则审查每个数据包，以便确定其是否与某一条包过滤规则匹配
- 过滤规则基于数据报头信息，对经过的每一个包进行检查：
 - IP 源地址、目标地址
 - ICMP的消息类型
 - TCP/UDP 源端口号、目标端口
 - 协议 (TCP, UDP, ICMP, BGP等)
- 常见包过滤设备/软件：路由器中的访问控制表ACL



网络层：包过滤技术的优缺点

- 优点

- 对应用透明；可以保护所有的服务
- 相对于高层防火墙，具有较好的网络性能
- 保持Internet 端到端的特性
- 无状态，防火墙负载较轻

- 缺点

- 没有认证功能
- 无法实施细粒度的访问控制不能防范IP地址欺骗
- 不能防范IP分片攻击

防火墙可以做什么

- 防火墙提供了单一阻塞点
 - 可以过滤掉一些潜在的攻击，防止了各种形式的IP欺骗和路由攻击
 - 可以进行用户身份认证、消息认证、数据加密
- 防火墙提供了一个安全事件监控点
 - 可以实施安全检查和警报
 - 可以关闭不使用的端口，禁止特定端口的特定流量，封锁木马等病毒
 - 可以禁止来自特殊站点的访问，防止来自不明入侵者的所有流量
- 防火墙是一个便利的平台
 - 可以方便地提供一些与网络安全无关的功能，例如地址转换器、网络管理等
 - 可以作为IPSec的平台，利用隧道模式实现虚拟专用网络

防火墙不可以做什么

- 防火墙需要用户定义访问控制规则，没有缺省配置
- 防火墙不能防止内部恶意的攻击者
- 防火墙无法控制没有经过它的连接
- 防火墙不能很好地防止病毒和信息扩散
- 防火墙不能替代内部网络系统的安全管理
- 防火墙无法防范全新的威胁和攻击



访问控制的基本概念

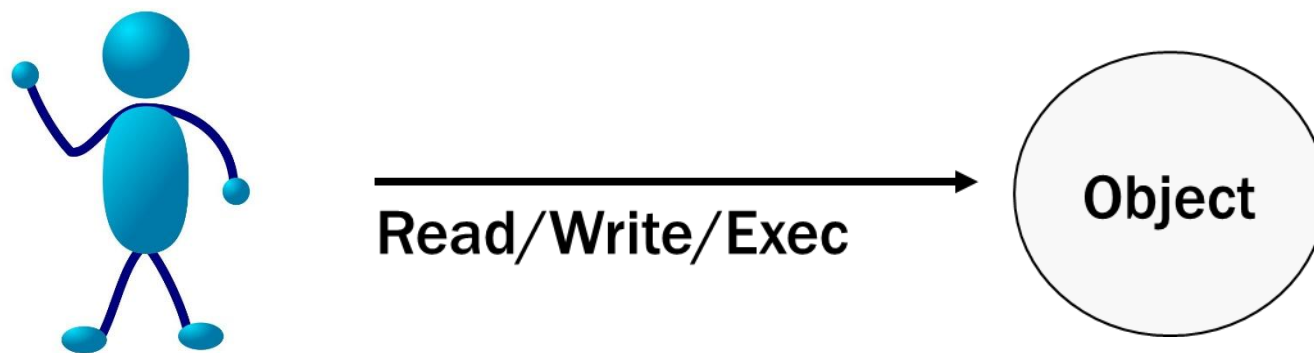


访问控制的基本概念

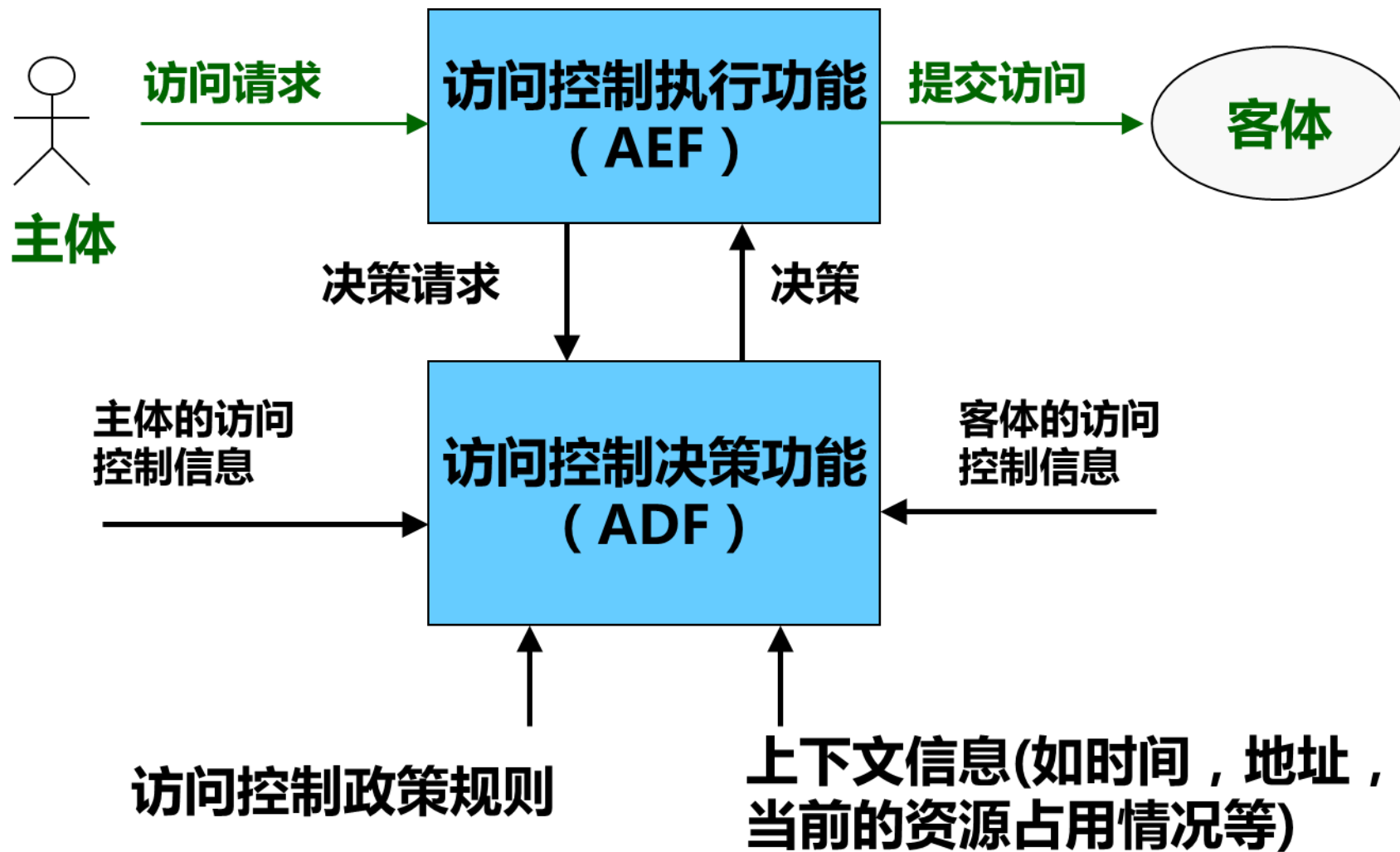
- 主体(Subject)
 - 主体是一个主动的实体，它提出对资源访问请求
 - 如用户，程序，进程等
- 客体(Object)
 - 含有被访问资源的被动实体
 - 如网络、计算机、数据库、文件、目录、程序、 外设等
- 访问(Access)
 - 对资源的使用，读、写、修改、删除等操作
 - 例如访问存储器、访问文件/目录/外设、访问数据库/网站等

访问控制的基本概念

- 访问可以被描述为一个三元组 (s, a, o)
 - 主体、发起者: Subject、Initiator
 - 客体、目标: Object、Target
 - 访问操作: Access



访问控制模型



访问控制的基本概念

- 访问控制信息(ACI)的表示
 - 主体访问控制属性
 - 客体访问控制属性
 - 访问控制政策规则
- 授权(Authorization)
 - 怎样把访问控制属性信息分配给主体或客体
 - 如何浏览、修改、回收访问控制权限

访问控制矩阵

- 按列看是客体的访问控制列表
 - access control list
- 按行看是主体的访问能力表
 - capability list

Subjects	Objects		
	O ₁	O ₂	O ₃
S ₁	Read/write		
S ₂		Write	
S ₃	Execute		Read

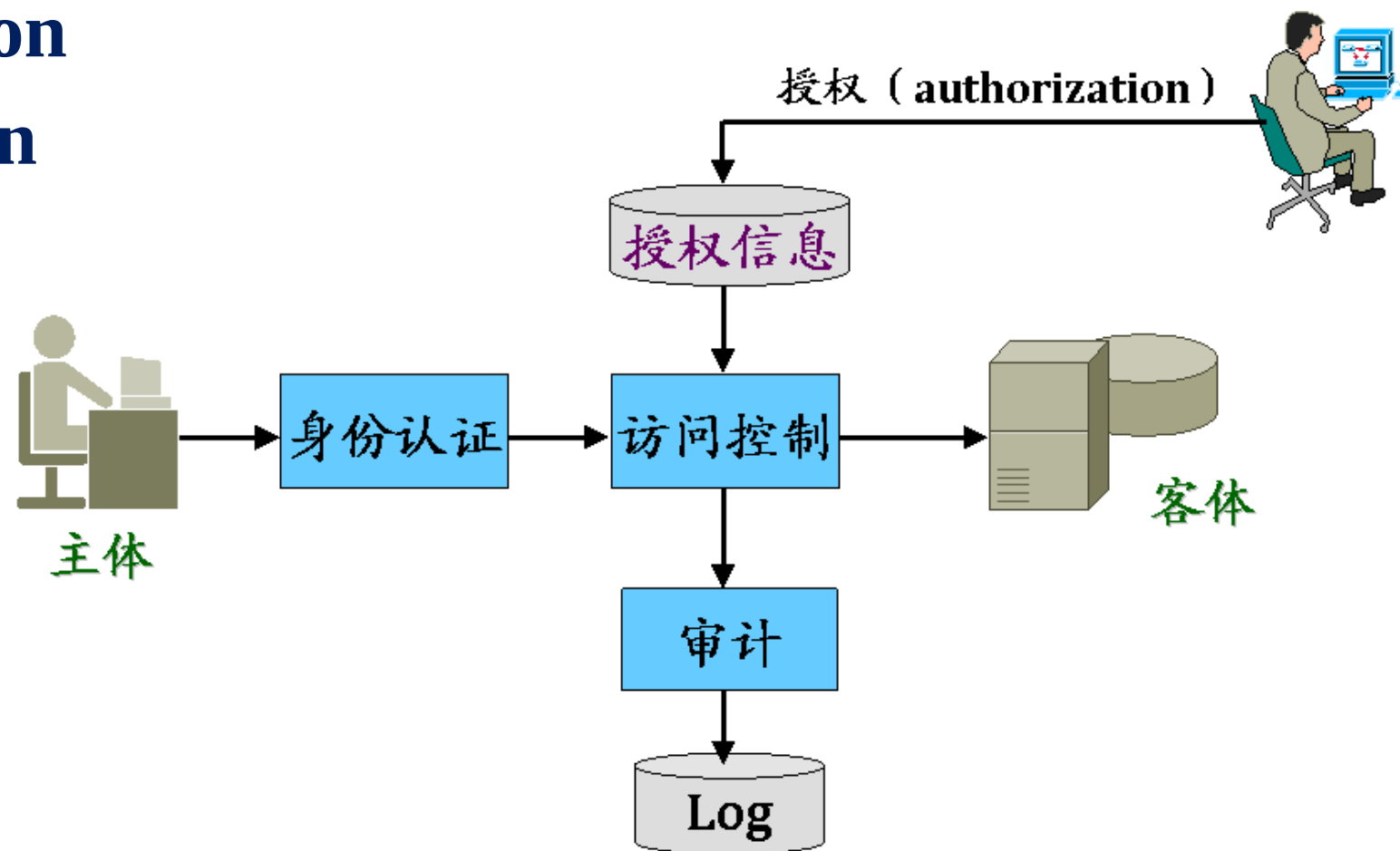
访问控制与其他安全机制的关系

- 认证、授权、审计 (AAA)

- Authentication

- Authorization

- Audit



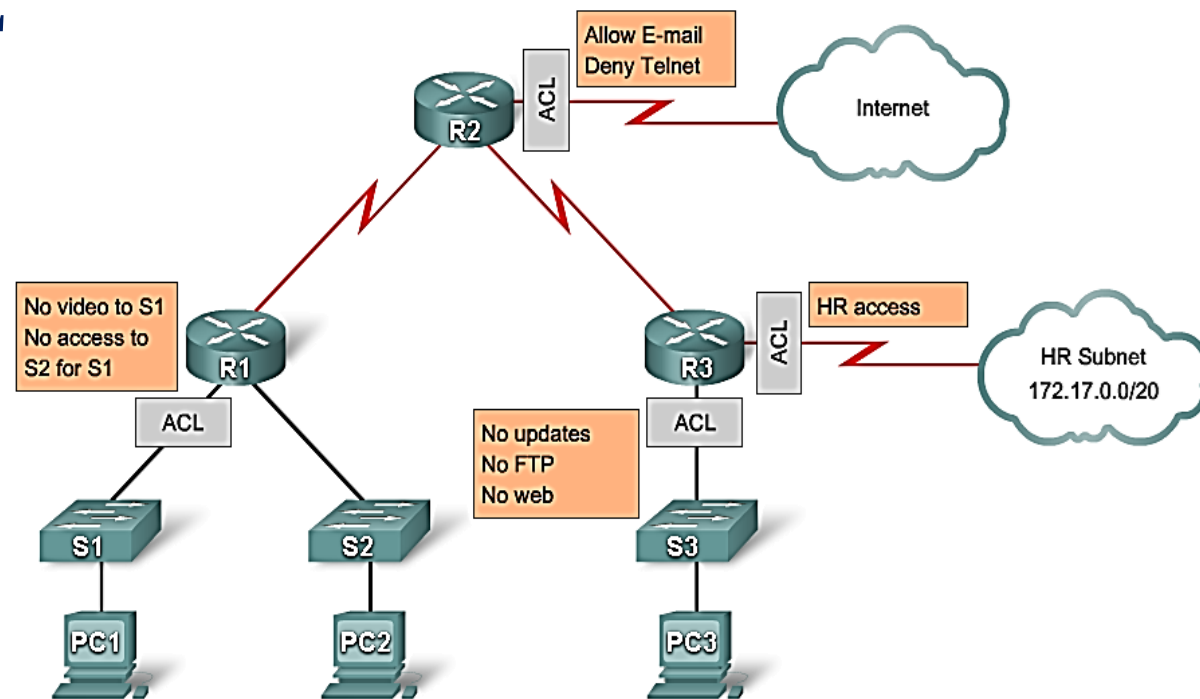


路由器中的 访问控制列表ACL

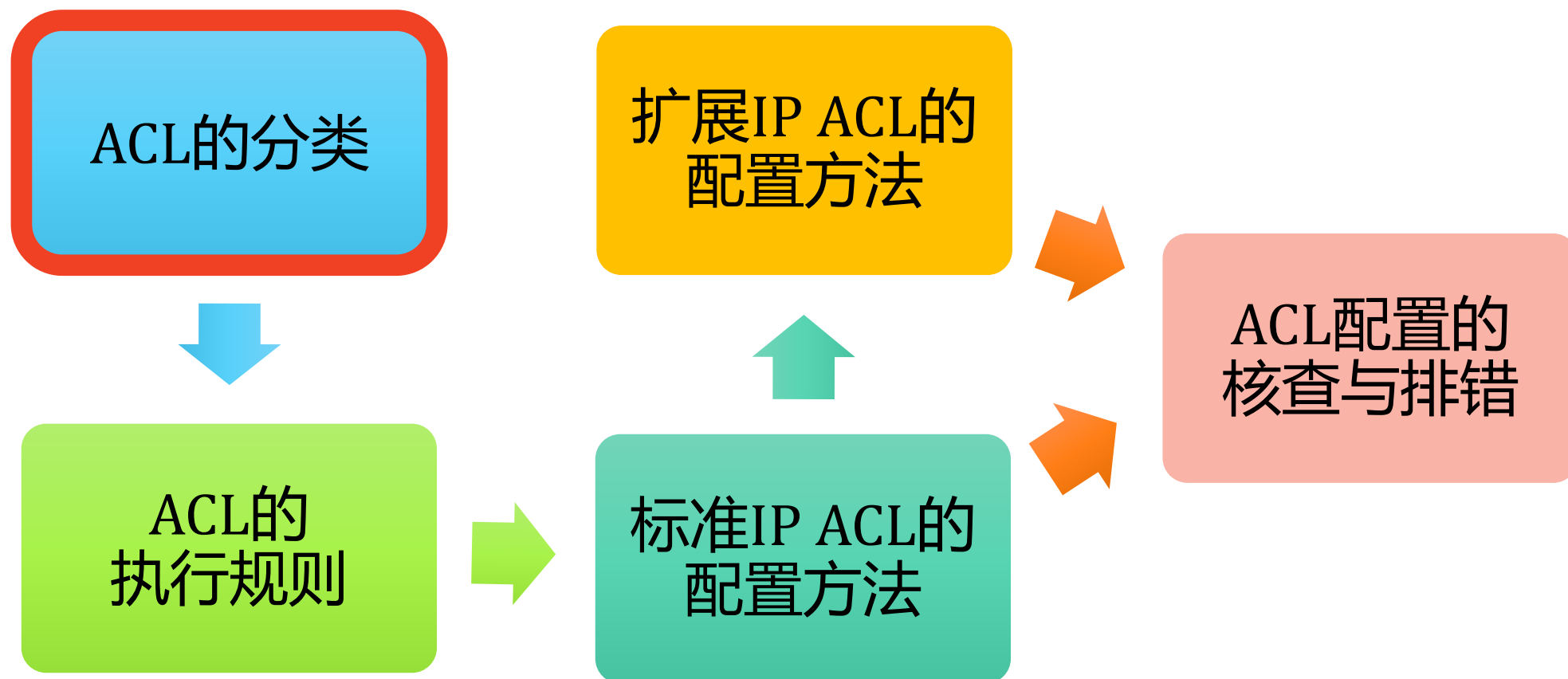


什么是访问控制列表ACL?

- ACL(Access Control List)是一组预先定义好的规则，被置于路由器的接口，根据进出数据包头中的信息，控制该数据包能否穿越路由器
- 路由器中的访问控制列表ACL是包过滤技术的具体实现，ACL可执行下列任务：
 - 限制网络流量
 - 提供基本的安全访问控制，禁止某些特征的数据包访问
 - 控制路由更新内容
 - 区分特定的数据流类型



访问控制列表ACL



ACL的分类

- 标准IP ACL

- 编号范围1-99以及1300-1999，限制条件为IP数据包头中的源IP地址

- 扩展IP ACL

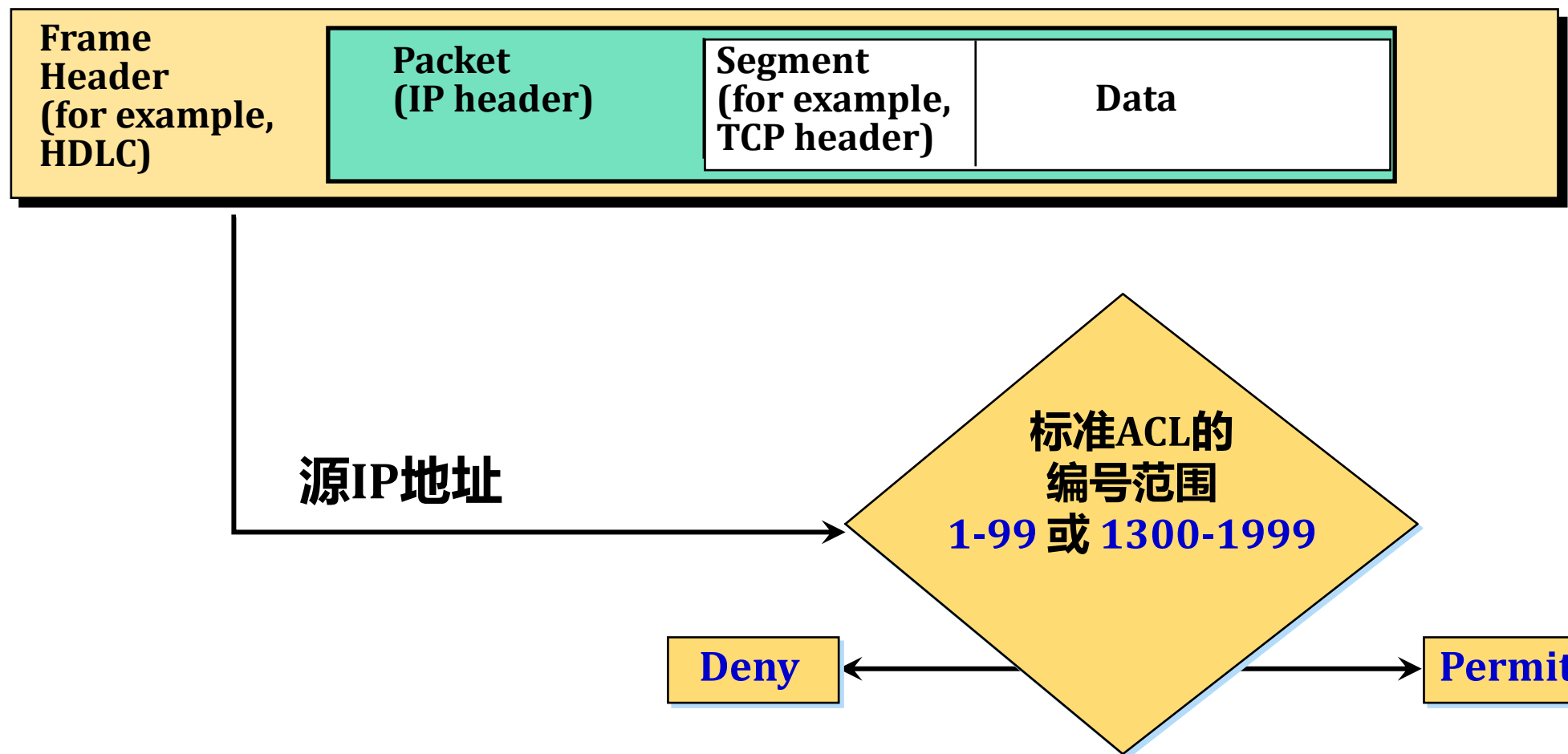
- 编号范围100-199以及2000-2699
- 限制条件为IP数据包头中的源、目的IP地址、协议类型和源、目的端口号

- 其余编号范围的ACL是针对其它网络协议的

Access List Type		Number Range/Identifier
IP	Standard	1-99 , 1300-1999
	Extended	100-199 , 2000-2699
	Named	Name (Cisco IOS 11.2 and late)
IPX	Standard	800-899
	Extended	900-999
	SAP filters	1000-1099
	Named	Name (IOS 11.2. F and later)

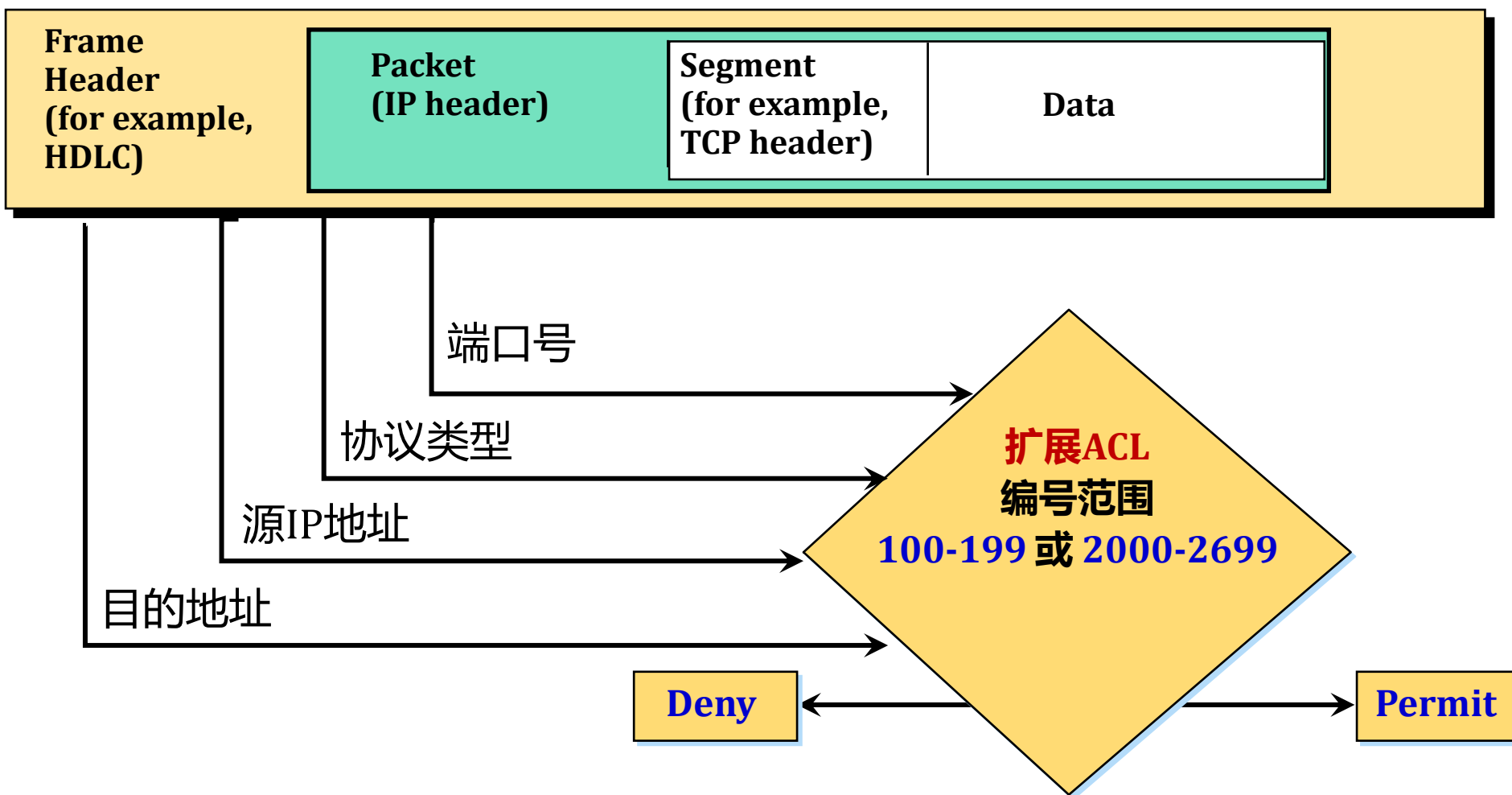
标准ACL的检查内容

TCP/IP数据包的结构图

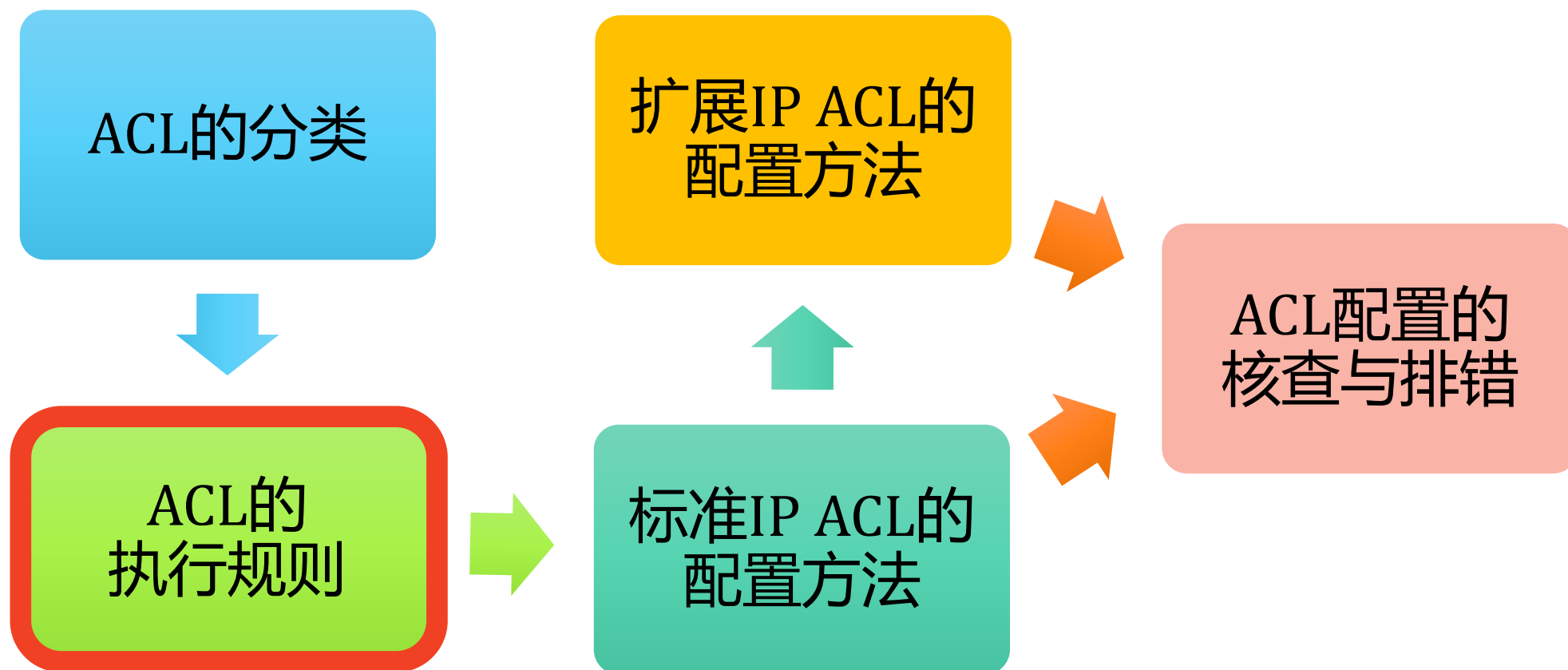


扩展ACL的检查内容

TCP/IP数据包的结构图

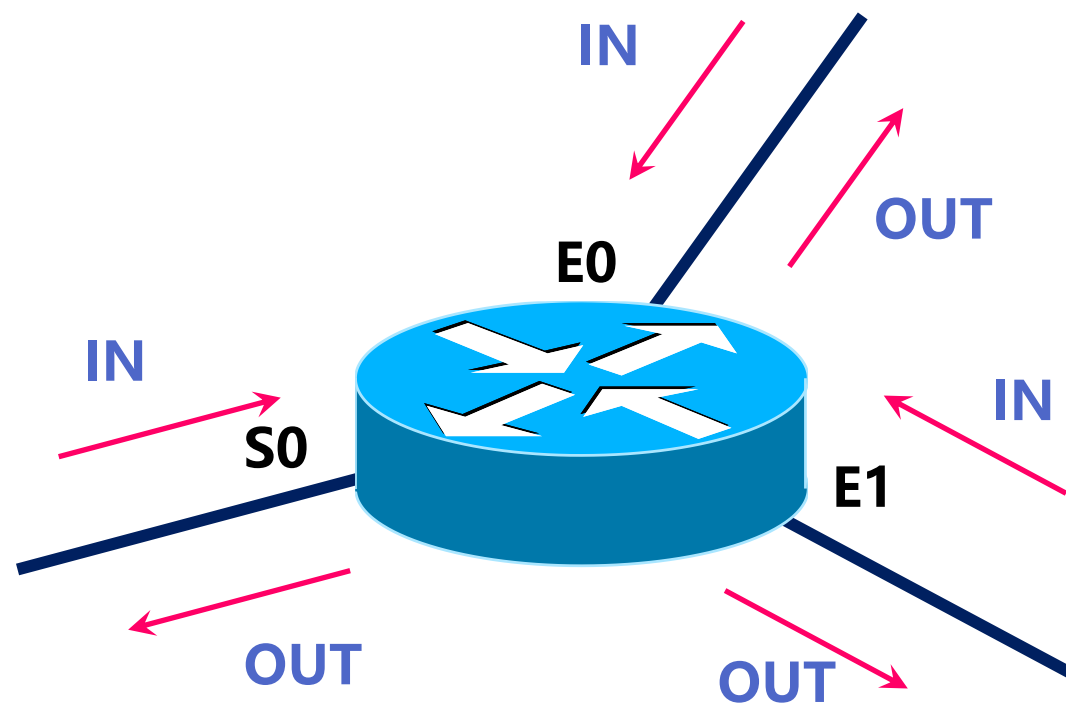


访问控制列表ACL



ACL的作用方向

- 设置规则：对于每个协议，每个路由器的每个接口的每个方向上只能设置一条ACL



ACL的配置规则

- 路由器总是自顶向下顺序检查所有规则
 - 未定义访问控制列表等于permit all
 - 最经常发生的规则放在列表的前面
 - 新增加的行将放在末尾
 - 设置了ACL后，最后一条永远是隐含拒绝一切deny all
- 配置规则时要从具体到一般，例如：
 - deny 192.168.2.0/24
 - permit 192.168.2.1
 - permit any

ACL的检查顺序

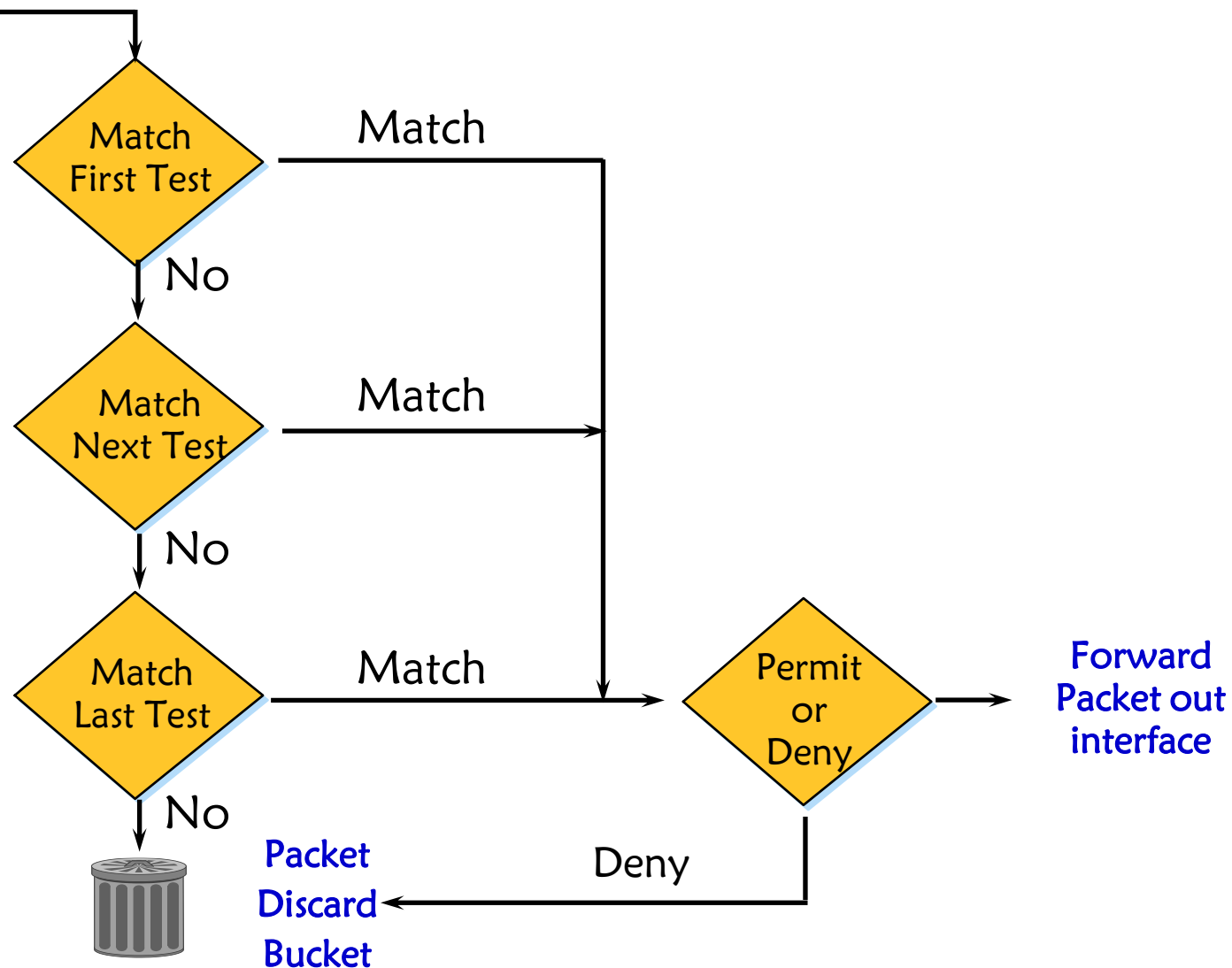
可路由协议的数据包

- 自顶向下逐条检查，匹配以后下面的条目不再检查：

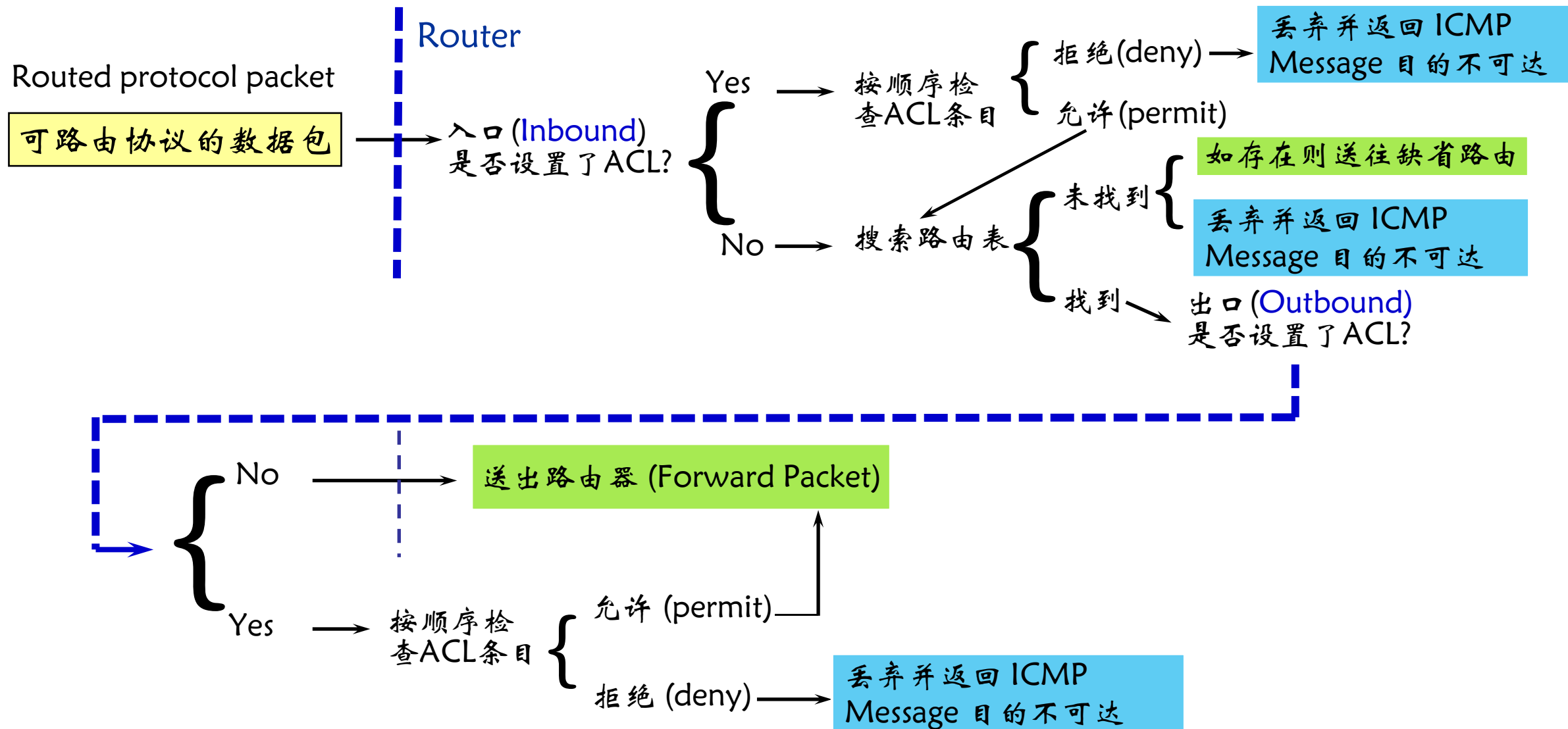
将条件严格的放在前面

- 最后一句总是隐含的deny any语句，除了显式允许的以外都拒绝：

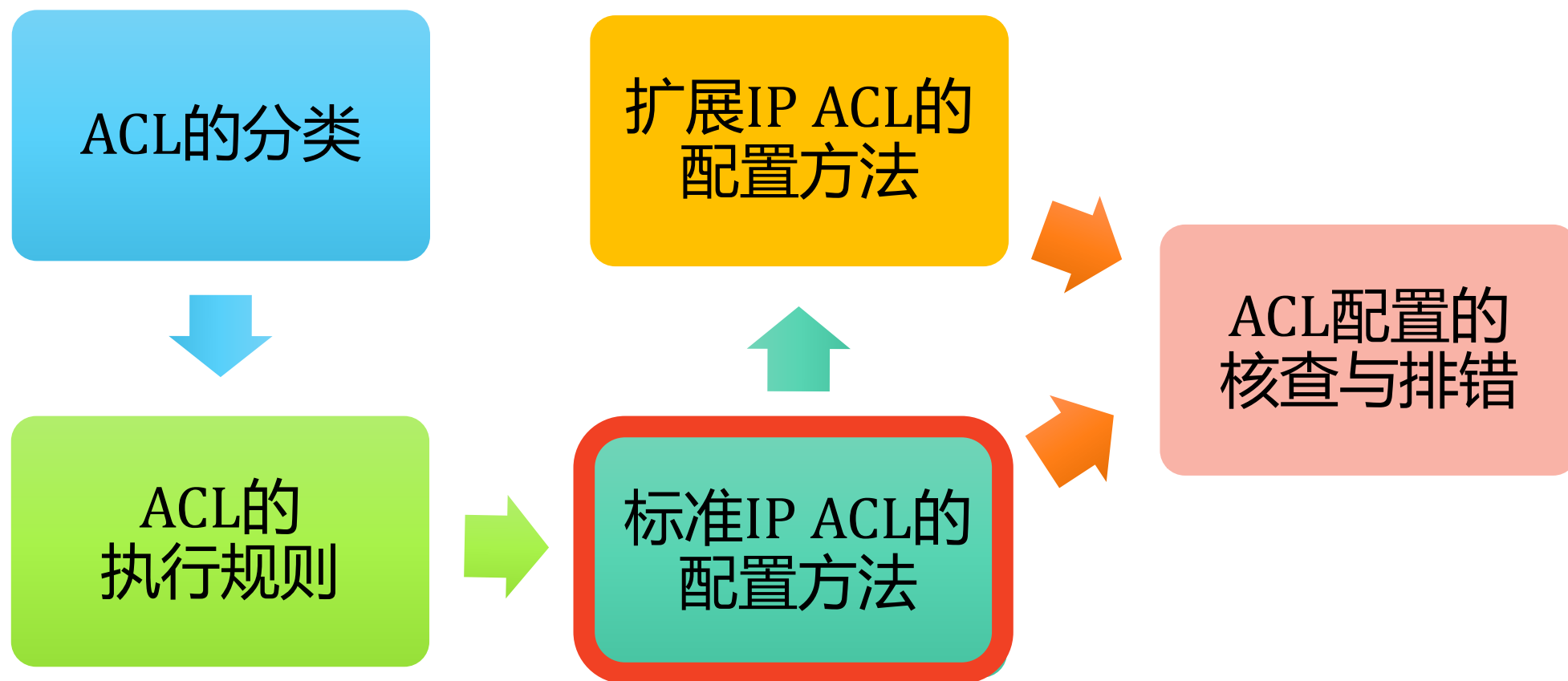
要求至少存在一条显式的permit 语句



ACL与路由的相互关系



访问控制列表ACL



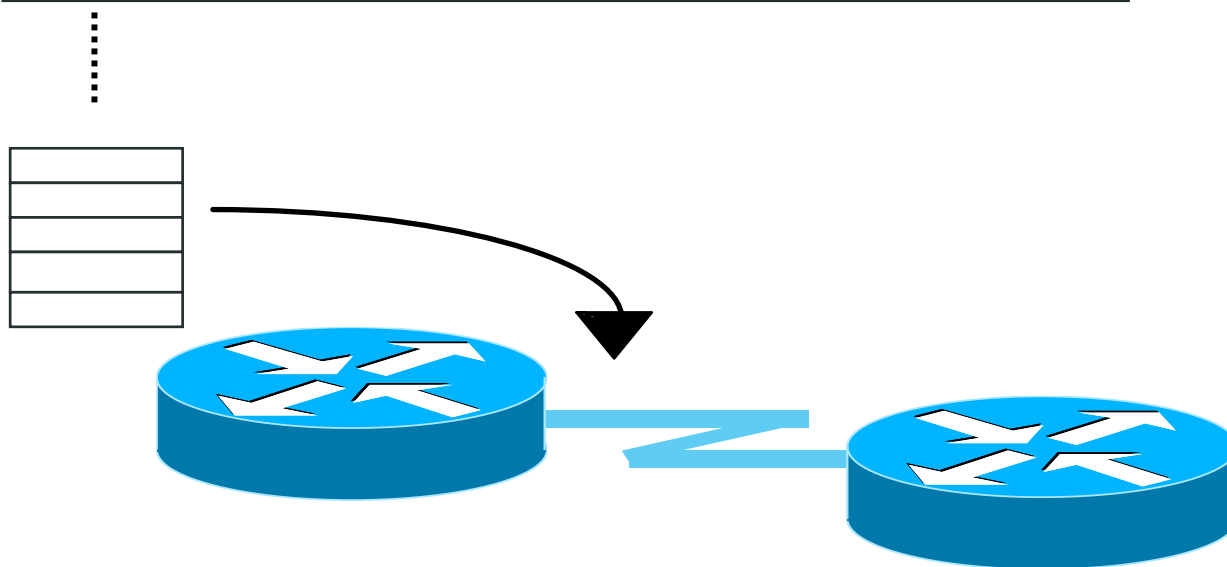
ACL的配置步骤

- 配置ACL的两个步骤:

1. 定制ACL的规则

2. 将规则应用到接口

access-list 1 deny	172.30.16.5 0.0.0.0
access-list 1 permit	172.30.16.0 0.0.0.255
access-list 1 deny	192.168.3.1 0.0.0.0
access-list 1 permit	192.168.1.0 0.0.0.255
access-list 1 deny	any



标准IP ACL的配置命令

- 定义标准ACL(编号范围 1- 99 和 1300 - 1999)

Router (config) #

```
access-list access-list-number { permit | deny }  
    { source [ source-wildcard ] | any } [log]
```

- 将ACL应用到特定接口

Router (config-if) #

```
ip access-group access-list-number { in | out }
```

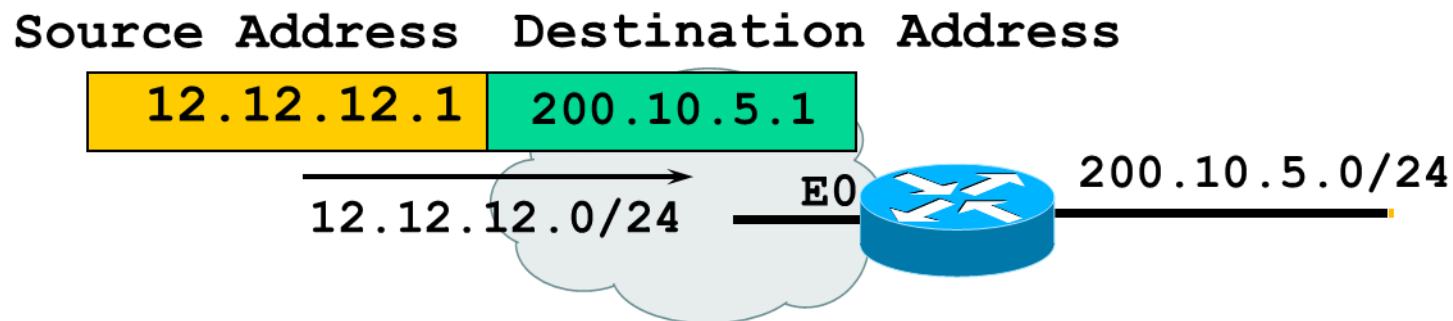
- Log (可选参数) 将匹配该条目的数据包数量信息发送到控制台，间隔5分钟发送一次

ACL通配符掩码的规则

- 通配符掩码位是0表示必须匹配前面地址对应的比特
- 通配符掩码位是1表示不必匹配前面地址对应的比特

Address	Wildcard	Matches
0.0.0.0	255.255.255.255	any address
131.108.0.0	0.0.255.255	network 131.108.0.0
131.104.7.11	0.0.0.0	host 131.104.7.11
255.255.255.255	0.0.0.0	local broadcast
131.111.8.0	0.0.7.255	subnet 131.111.8.0/21

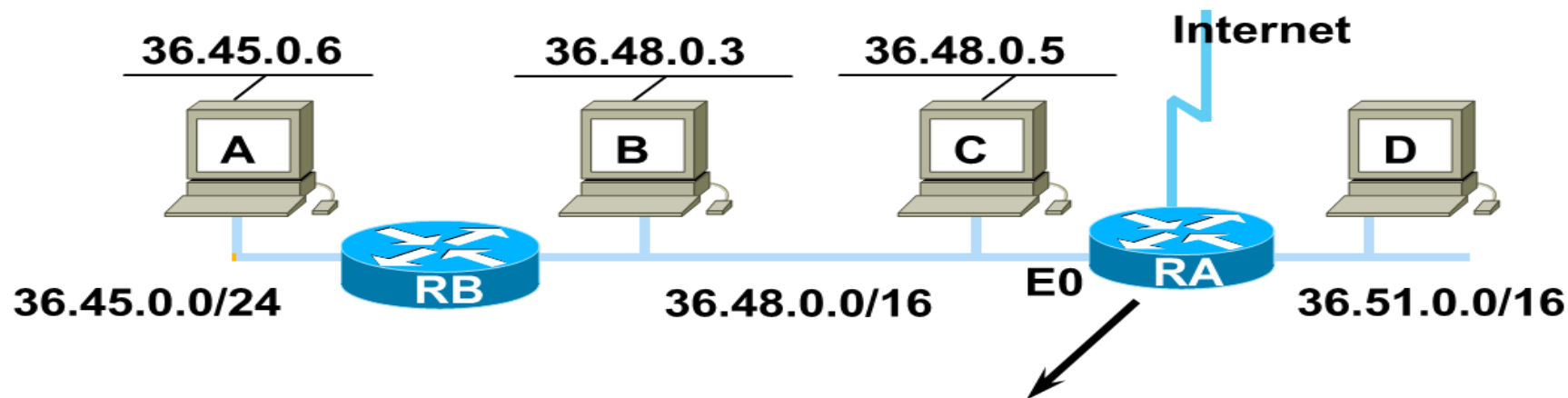
ACL的工作过程



```
access-list 3 permit 12.0.0.0 0.255.255.255
interface Ethernet 0
 ip access-group 3 in
```

IP address	12.0.0.0	00001100	00000000	00000000	00000000
wildcard mask	0.255.255.255	00000000	11111111	11111111	11111111
	12.any.any.any	00001100	any	any	any
Example	16.12.12.1	00010000	00001100	00001100	00000001
	0.255.255.255	00000000	11111111	11111111	11111111

标准IP ACL配置示例



```
RA(config)# access-list 1 deny 36.48.0.3 0.0.0.0
RA(config)# access-list 1 permit 36.48.0.0 0.0.255.255
! (Note: all other access implicitly denied)
RA(config)# interface ethernet 0
RA(config-if)# ip access-group 1 in
```

```
RA(config)# access-list 1 permit 36.48.0.0 0.0.255.255
RA(config)# access-list 1 deny 36.48.0.3 0.0.0.0
RA(config)# interface ethernet 0
RA(config-if)# ip access-group 1 in
```

→ 被前面的语句所包含，
因此无效

特殊的通配符掩码表示方法

- 匹配所有的比特位 (match all)

172.30.16.29



Wildcard Mask: 0.0.0.0 (检查所有比特)

标准语法：

```
access-list 1 permit 172.30.16.29 0.0.0.0
```

可使用关键字 `host` 表示为：

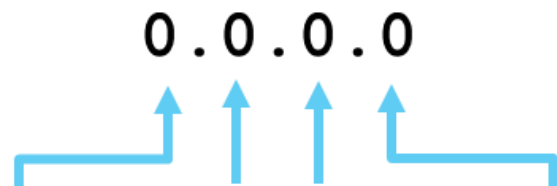
```
access-list 1 permit host 172.30.16.29
```

如果不写通配符掩码隐含为 0.0.0.0，例如：

```
access-list 1 permit 172.30.16.29
```

特殊的通配符掩码表示方法

- 忽略所有的比特位 (ignore all)



Wildcard Mask: 255.255.255.255 (忽略所有比特)

标准语法：

```
access-list 1 permit 0.0.0.0 255.255.255.255
```

可使用关键字 any 表示为：

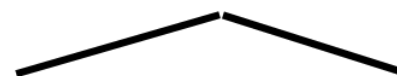
```
access-list 1 permit any
```

案例1：复杂通配符掩码的计算方法

- 问题：如果IP子网的变化范围172.30.16.0/24 至 172.30.31.0/24，要求用一条语句表示

- 第3个字节前4个比特是相同部分，必须完全匹配，通配符为0；
- 后面4个比特是全排列，为任意组合，因此通配符为1。
- 通配符以十进制形式表示为：
0.0.15.255

172.30.16.0



0 0 0 1 0 0 0 0

0 0 0 1 0 0 0 1

0 0 0 1 0 0 1 0

...

...

0 0 0 1 1 1 1 1

通配符掩码

0 0 0 0 1 1 1 1

对应的十进制数

16

17

18

31

15

最终配置结果：

```
access-list 1 permit 172.30.16.0 0.0.15.255
```

案例2：复杂通配符掩码的计算方法

- 问题：如果IP子网的变化范围改为 172.30.16.0/24 至 172.30.30.0/24，该如何配置？

```
access-list 1 deny 172.30.31.0 0.0.0.255  
access-list 1 permit 172.30.16.0 0.0.15.255
```

案例3：复杂通配符掩码的计算方法

- 问题：如果IP子网允许通过的地址范围 200.10.5.10 ~ 15，该如何配置？

分析最后一个字节的变化范围

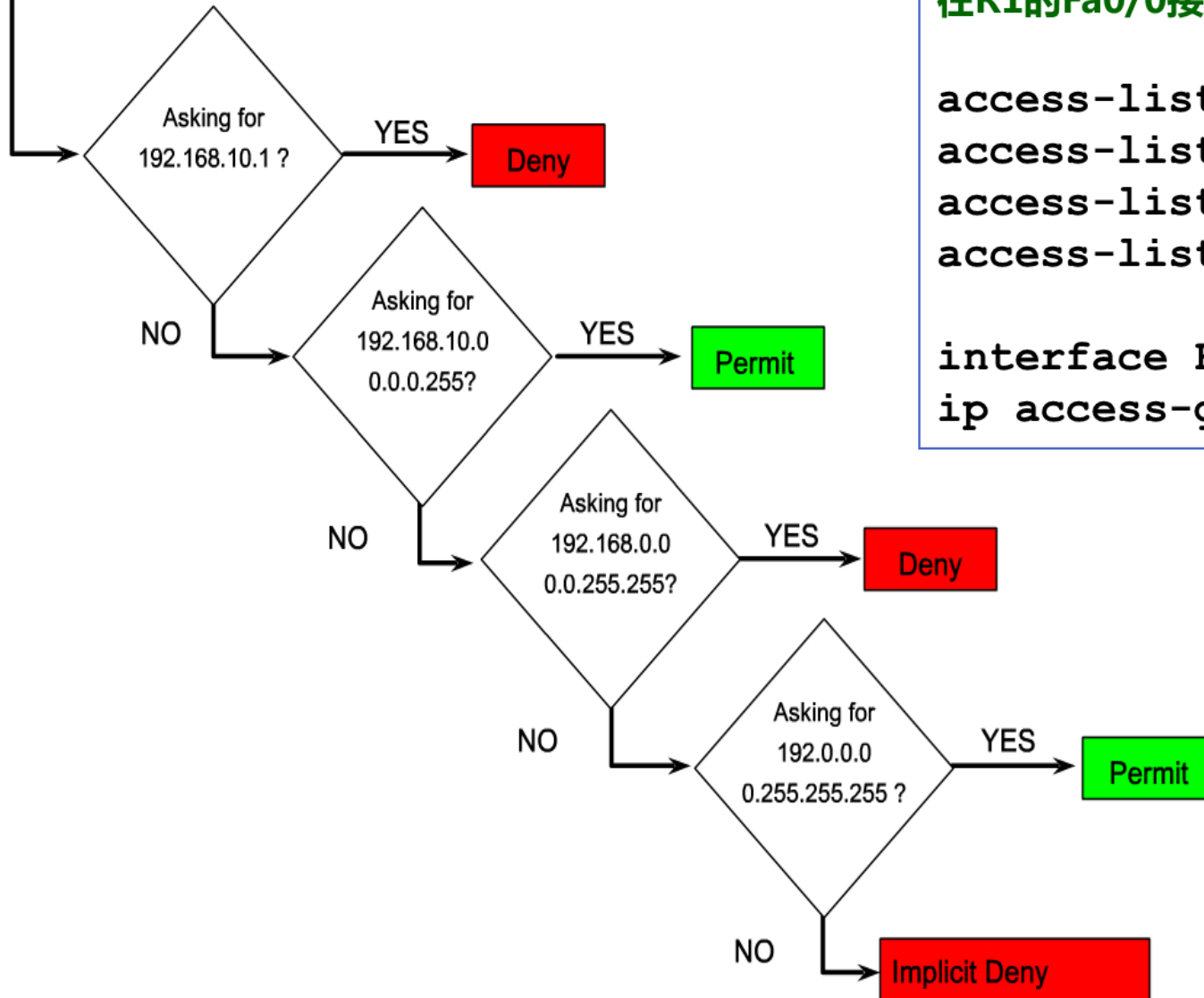
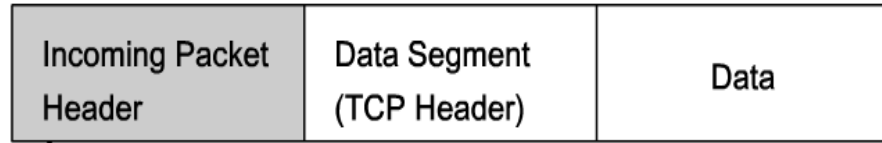
00001010	10
00001011	11
00001100	12
00001101	13
00001110	14
00001111	15

通配符掩码	00001010	(10)
	00001011	(11)
	00000001	(1)

通配符掩码	00001100	(12)
	00001101	(13)
	00001110	(14)
	00001111	(15)
	00000011	(3)

最终配置结果：

```
access-list 3 permit 200.10.5.10 0.0.0.1
access-list 3 permit 200.10.5.12 0.0.0.3
```

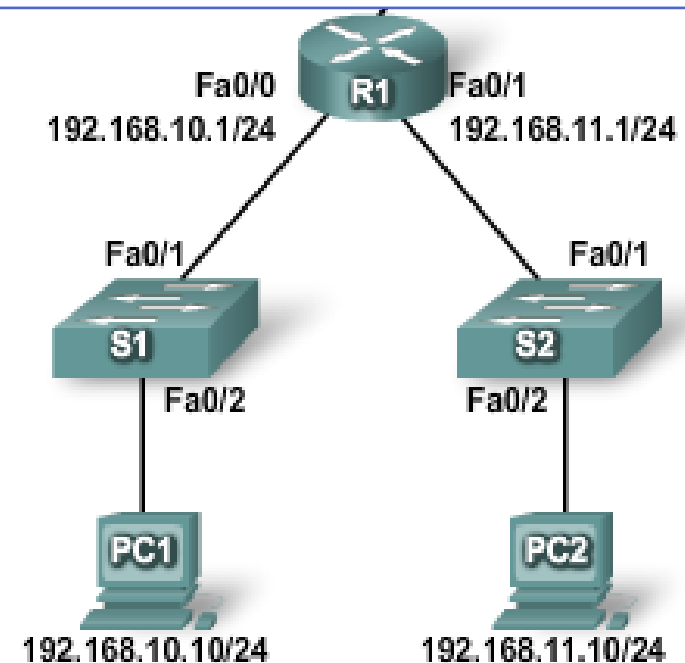


案例4：标准IP ACL配置

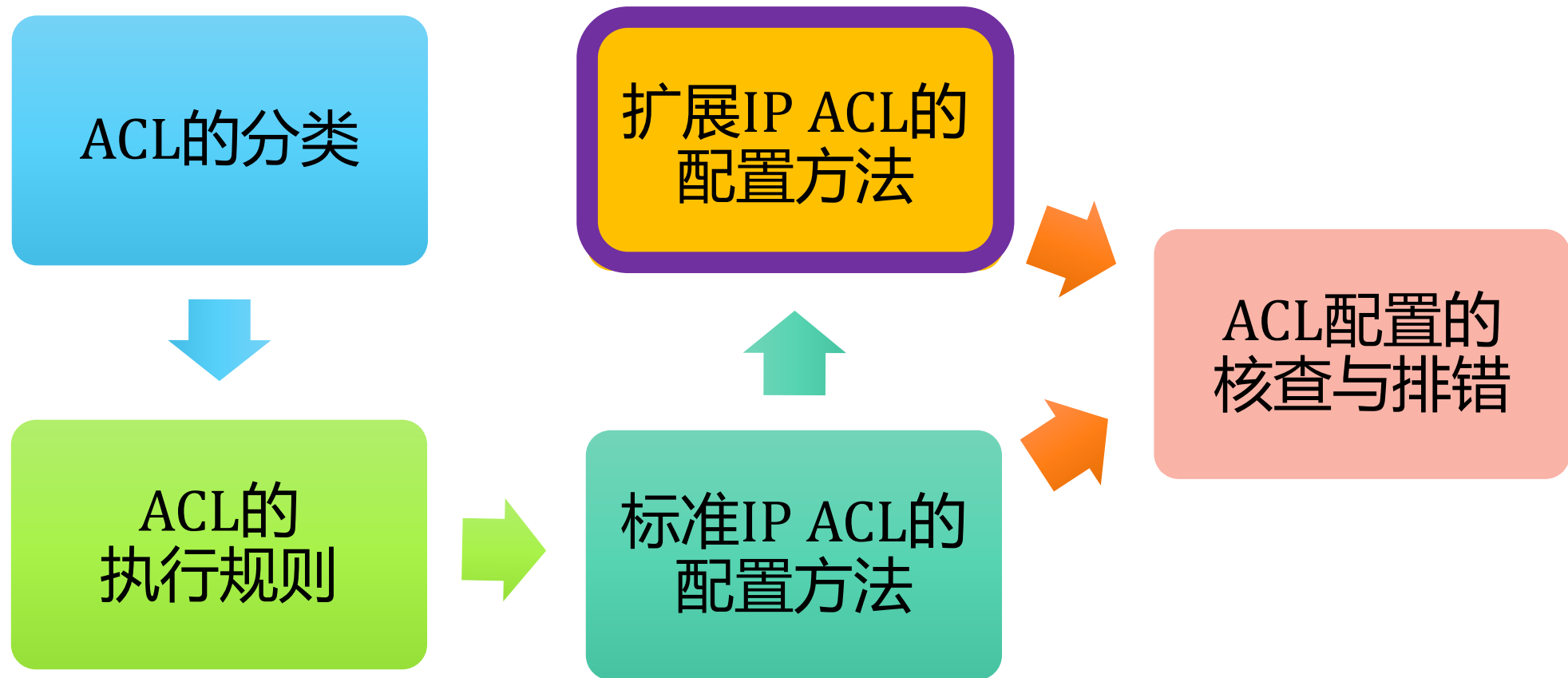
在R1的Fa0/0接口的入方向设置下列标准IP ACL:

```
access-list 7 deny 192.168.10.10
access-list 7 permit 192.168.10.0 0.0.0.255
access-list 7 deny 192.168.0.0 0.0.255.255
access-list 7 permit 192.0.0.0 0.255.255.255
```

```
interface Fa0/0
ip access-group 7 in
```

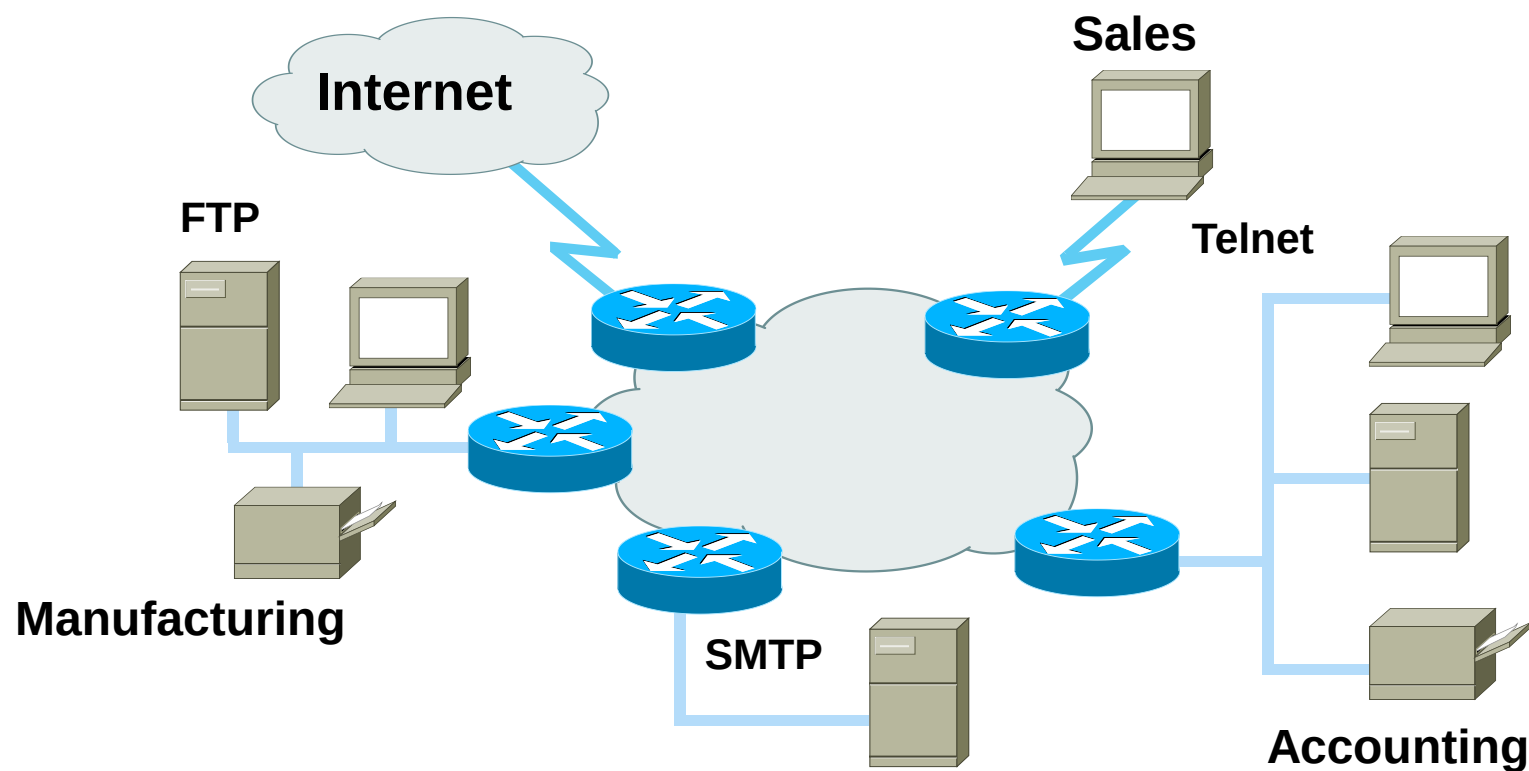


访问控制列表ACL



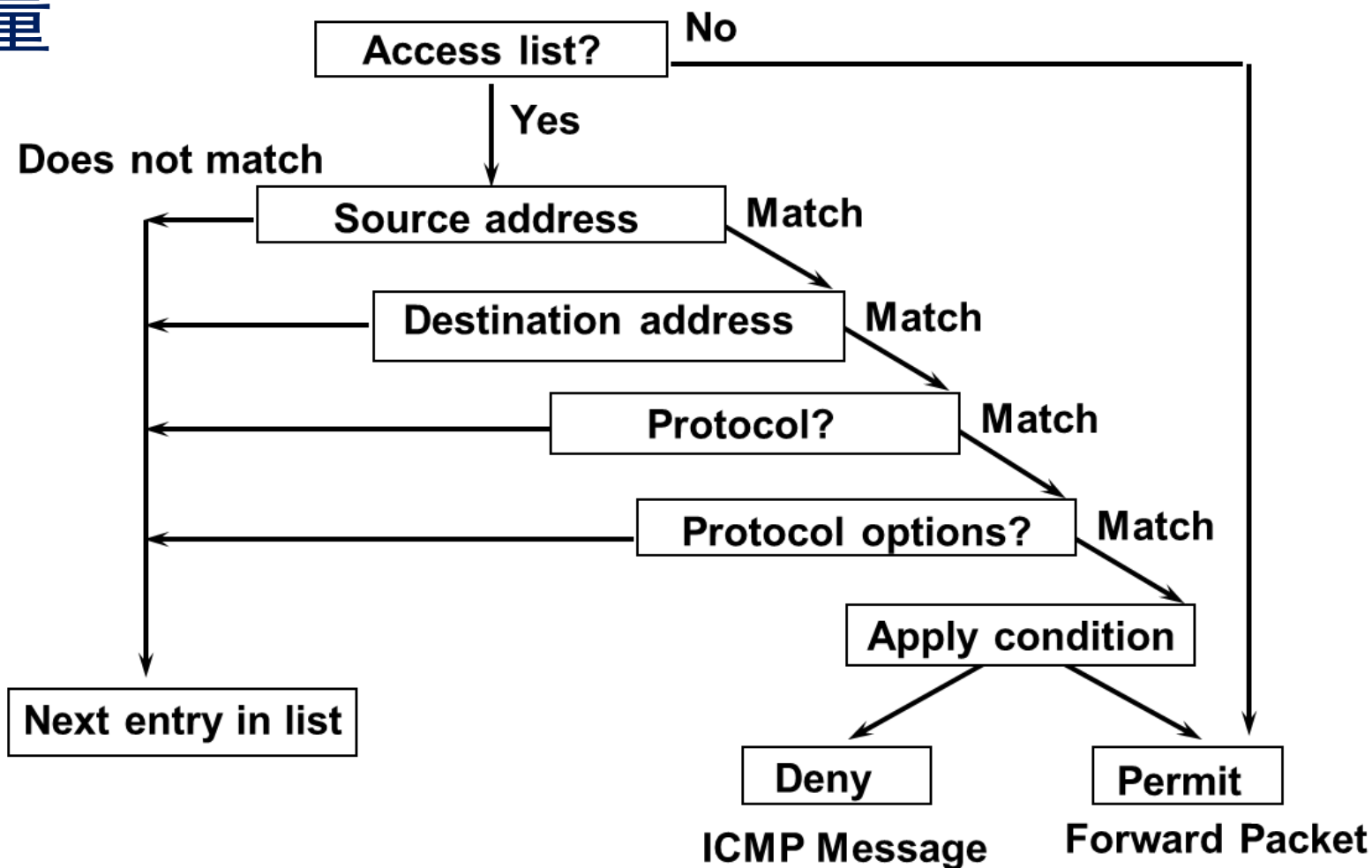
标准IP ACL的局限性

- 标准IP ACL只能根据包头中源IP地址控制流量



扩展IP ACL的优势

- 扩展IP ACL可以根据数据源地址、目的地址、上层应用程序控制流量



扩展IP ACL的配置命令

- 定义扩展IP ACL(编号范围 100- 199 和 2000 - 2699)

Router (config) #

```
access-list access-list-number { permit | deny }  
    { protocol | protocol-keyword }  
    { source source-wildcard | any }  
    { destination destination-wildcard | any }  
    [ protocol-specific options ]
```

Protocol 字段关键字：ip, icmp, tcp, 和 udp 等。

Protocol-specific选项字段根据协议不同而变化。

- 将ACL应用到特定接口

Router (config-if) #

```
ip access-group access-list-number { in | out }
```

Protocol字段为TCP的语法

Router (config) #

```
access-list access-list-number { permit | deny } tcp
    { source source-wildcard | any }
    [ operator source-port | source-port ]
    { destination destination-wildcard | any }
    [ operator destination-port | destination-port ]
    [ established ]
```

Operator (可选) 其内容为: lt, gt, eq, neq 或 range .

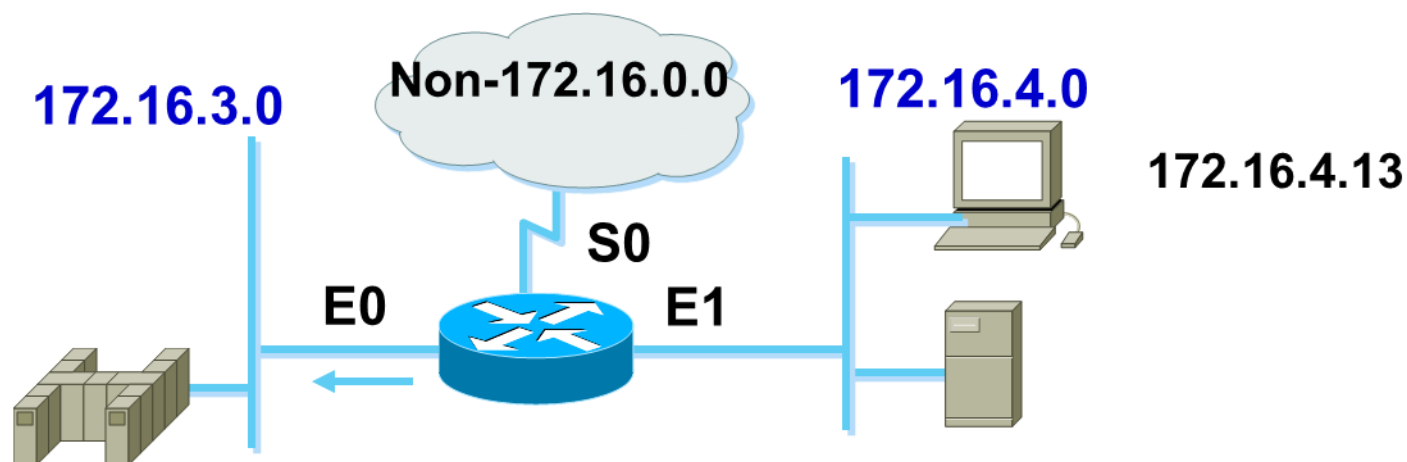
TCP端口号对应的协议

1	tcpmux TCP 端口服务多路复用	53	domain 域名服务 (如 BIND)
5	rje 远程作业入口	63	whois++ WHOIS++, 被扩展了的 WHOIS 服务
7	echo Echo 服务	67	bootps 引导协议 (BOOTP) 服务; 还被动态主机配置协议 (DHCP) 服务使用
9	discard 用于连接测试的空服务	68	bootpc Bootstrap (BOOTP) 客户; 还被动态主机配置协议 (DHCP) 客户使用
11	systat 用于列举连接了的端口的系统状态	69	tftp 小文件传输协议 (TFTP)
13	daytime 给请求主机发送日期和时间	70	gopher Gopher 互联网文档搜寻和检索
17	qotd 给连接了的主机发送每日格言	71	netrjs-1 远程作业服务
18	mss 消息发送协议	72	netrjs-2 远程作业服务
19	chargen 字符生成服务; 发送无止境的字符流	73	netrjs-3 远程作业服务
20	ftp-data FTP 数据端口	73	netrjs-4 远程作业服务
21	ftp 文件传输协议 (FTP) 端口	79	finger 用于用户联系信息的 Finger 服务
22	ssh 安全 Shell (SSH) 服务	80	http 超文本传输协议 (HTTP)
23	telnet Telnet 服务	88	kerberos Kerberos 网络验证系统
25	smtp 简单邮件传输协议 (SMTP)	95	supdup Telnet 协议扩展
37	time 时间协议		
39	rlp 资源定位协议		
42	nameserver 互联网名称服务		
43	nicname WHOIS 目录服务		
49	tacacs 用于终端访问控制器访问控制系统		
50	re-mail-ck 远程邮件检查协议		

端口号参见RFC 1700文档

案例：协议字段为TCP的扩展IP ACL

- 问题：禁止来自子网172.16.4.0/24的流量访问目的子网172.16.3.0/24中FTP服务，其它流量允许通过。



```
access-list 101 deny tcp 172.16.4.0 0.0.0.255 172.16.3.0 0.0.0.255 eq 21
access-list 101 deny tcp 172.16.4.0 0.0.0.255 172.16.3.0 0.0.0.255 eq 20
access-list 101 permit ip any any
(implicit deny all)
(access-list 101 deny ip 0.0.0.0 255.255.255.255 0.0.0.0 255.255.255.255)

interface ethernet 0
ip access-group 101 out
```

Protocol字段为UDP的语法

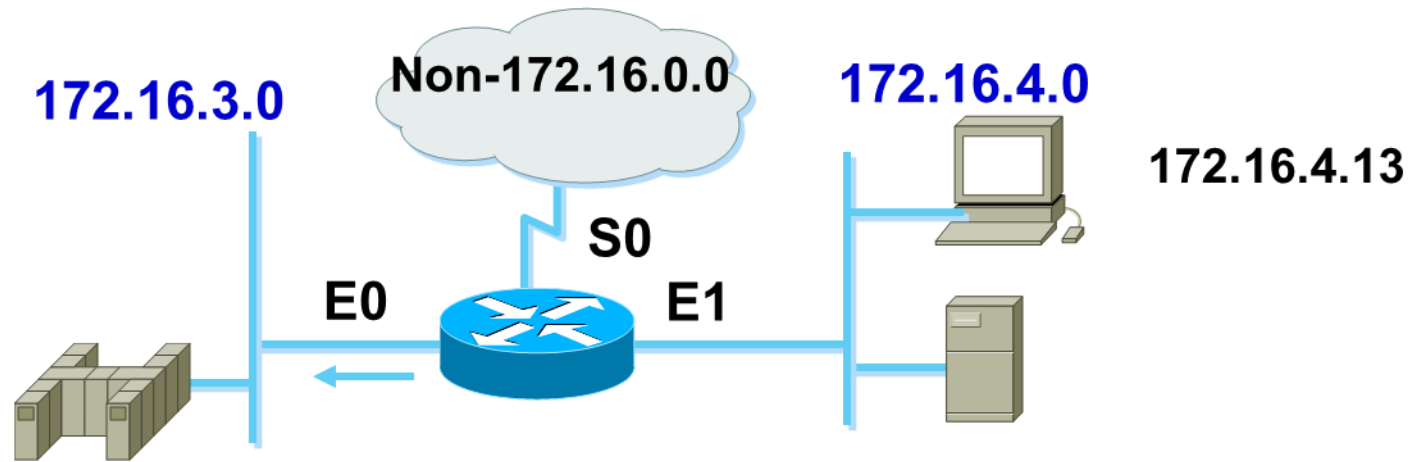
Router (config) #

```
access-list access-list-number { permit | deny } udp
    { source source-wildcard | any }
    [ operator source-port | source-port ]
    { destination destination-wildcard | any }
    [ operator destination-port | destination-port ]
```

Operator (可选) 其内容为: lt, gt, eq, neq 或 range .

案例：协议字段为UDP的扩展IP ACL

- 问题：禁止来自子网172.16.4.0/24的流量访问172.16.3.0/24子网中的TFTP服务，其它流量允许通过。



```
access-list 101 deny udp 172.16.4.0 0.0.0.255 any eq 69
access-list 101 permit ip any any
(implicit deny all)

interface ethernet 0
ip access-group 101 out
```


Protocol字段为ICMP的语法

Router (config) #

```
access-list access-list-number { permit | deny } icmp
    { source source-wildcard | any }
    { destination destination-wildcard | any }
    [ icmp-type [ icmp-code ] | icmp-message ]
```

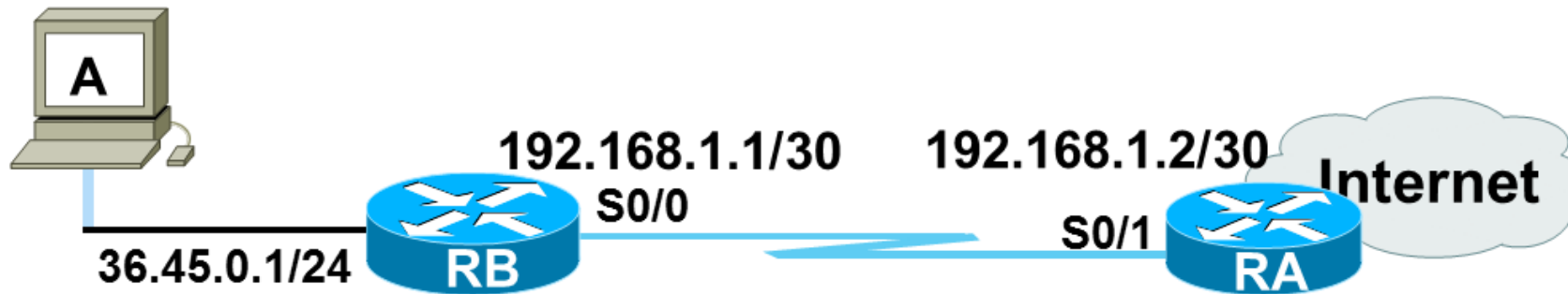
icmp-type 参见下一页内容

- 部分ICMP 消息类型名称
- 完整的ICMP信息参见 RFC 792 文档

administratively-prohibited	information reply	port unreachable
alternate-address	mask-reply	reassembly-timeout
conversion-error	mask-request	redirect
dod-host-prohibited	mobile-redirect	router-advertisement
dod-net-prohibited	net-redirect	router-solicitation
echo	net-tos-redirect	source-quench
echo-reply	net-tos-unreachable	source-route-failed
general-parameter-problem	net-unreachable	time-exceeded

案例：协议字段为ICMP的扩展IP ACL

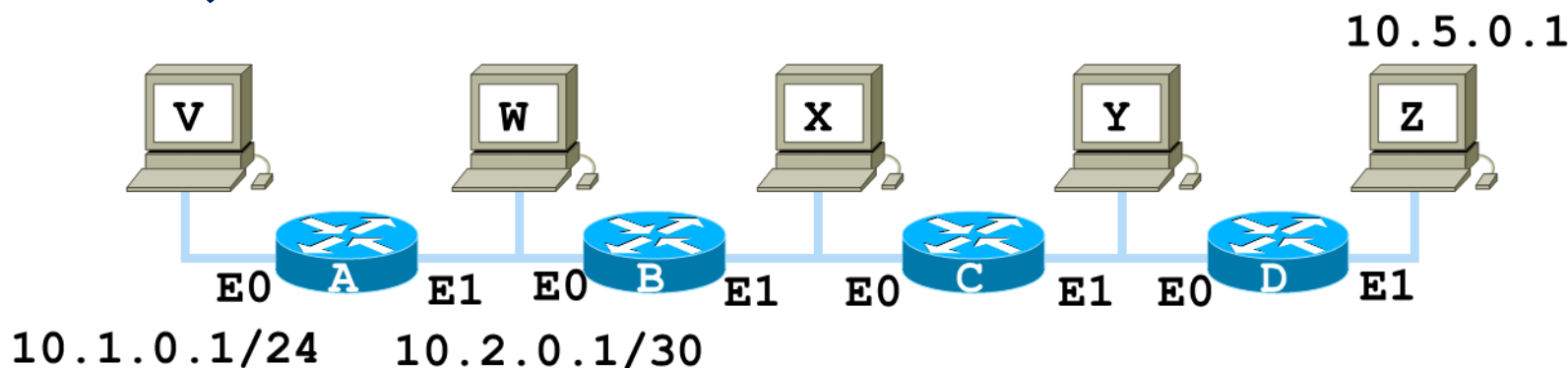
- 问题：要求在RB上能PING通RA的S0/1接口地址，但不允许来自RA及互联网上的流量PING RB的任何接口地址，其它流量允许通过，应该如何配置？



```
RB(config)# access-list 100 deny icmp any host 192.168.1.1
RB(config)# access-list 100 deny icmp any host 36.45.0.1
RB(config)# access-list 100 permit ip any any
RB(config)# interface S0/0
RB(config-if)# ip access-group 100 in
```

案例：ACL

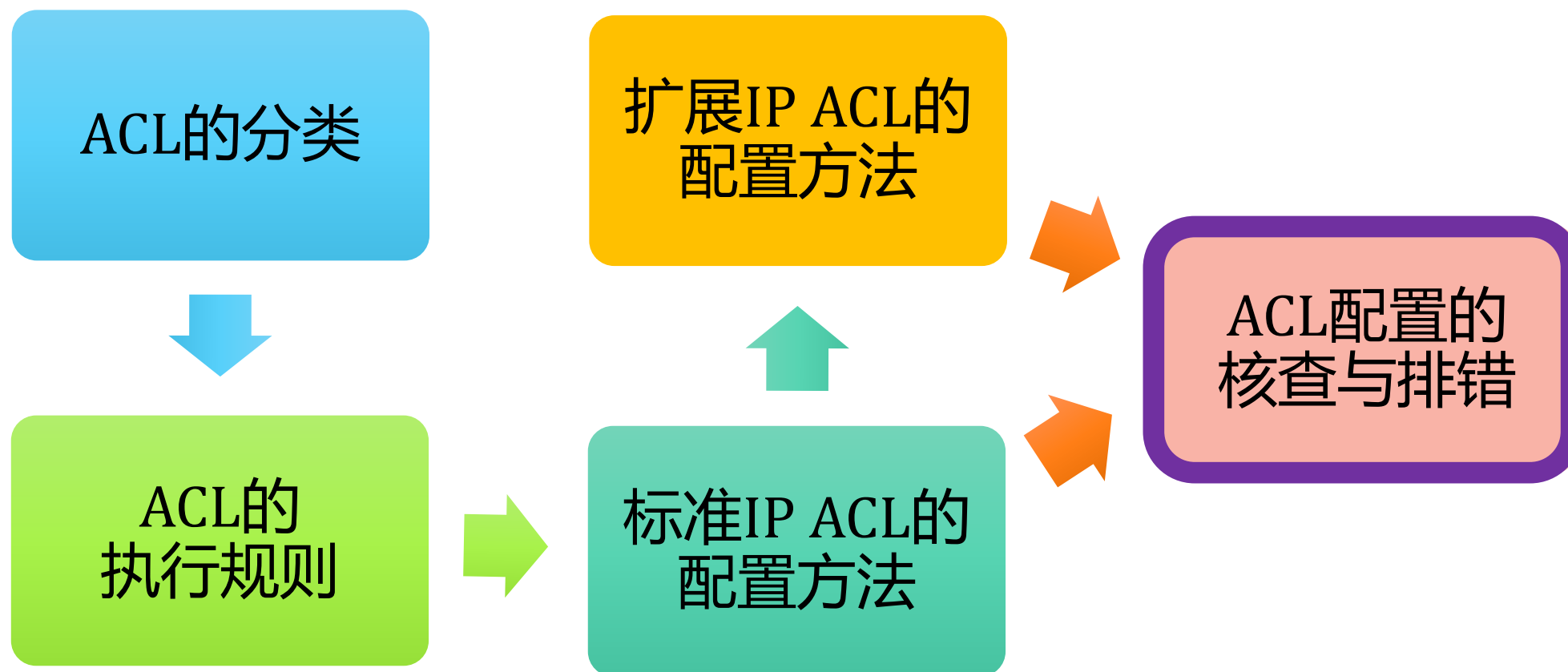
- 问题：在路由器A右侧的网络中，只允许主机 Z Telnet 路由器A，其它类型流量不能Telnet路由器A，要求使用扩展IP ACL，如何设置？



```
RA(config)# access-list 100 permit tcp host 10.5.0.1 host 10.2.0.1 eq 23
RA(config)# access-list 100 permit tcp host 10.5.0.1 host 10.1.0.1 eq 23
RA(config)# access-list 100 deny tcp any host 10.2.0.1 eq 23
RA(config)# access-list 100 deny tcp any host 10.1.0.1 eq 23
RA(config)# access-list 100 permit ip any any

RA(config)# interface Ethernet1
RA(config-if)# ip access-group 100 in
```

访问控制列表ACL



检查接口上是否设置了ACL

```
Router# show ip interface e0
Ethernet0 is up, line protocol is up
  Internet address is 10.1.1.11/24
  Broadcast address is 255.255.255.255
  Address determined by setup command
  MTU is 1500 bytes
  Helper address is not set
  Directed broadcast forwarding is disabled
  Outgoing access list is not set
  Inbound access list is 1
  Proxy ARP is enabled
  Security level is default
  Split horizon is enabled
  ICMP redirects are always sent
  ICMP unreachable are always sent
  ICMP mask replies are never sent
  IP fast switching is enabled
  IP fast switching on the same interface is disabled
  IP Feature Fast switching turbo vector
  IP multicast fast switching is enabled
  IP multicast distributed fast switching is disabled
<text omitted>
```

显示访问控制列表的命令

- 显示所有协议的访问控制列表

Router #

```
show access-lists [ access-list-number ]
```

- 显示IP协议的访问控制列表

Router #

```
show ip access-lists [ access-list-number ]
```

- 案例

```
Router# show ip access-lists
Extended IP access list 101
  deny udp any any eq ntp
  permit tcp any any
  permit udp any any eq tftp
  permit icmp any any
  permit udp any any eq dns
Router#
```

ACL的配置规则总结

- 对于每个协议，在每个路由器接口的每个方向上只能设置一条ACL，后写入的覆盖先前的
- 自顶向下逐条检查，匹配后其余条目不再检查：将条件严格的放在前面
- 最后一句是隐含的deny any语句，至少需要存在一条显式的permit语句；未定义的ACL (空ACL)相当于permit any
- 新增加的语句总是置于最后一行
- 访问控制列表不能限制起源于本路由器的流量



Thanks a lot !

Activity is the only road to knowledge

Computer Network Security